

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỖI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

**BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC FPT**

**KIẾN TRÚC NHẬN THỨC HAI TẦNG CHO PHÁT HIỆN
VÀ PHẢN HỒI MỐI ĐE DỌA TỰ ĐỘNG SỬ DỤNG AI
TÁC TỬ (AGENTIC AI)**

thực hiện bởi

Nguyễn Đức Bình

Luận văn được nộp để đáp ứng yêu cầu
của học vị Thạc sĩ Kỹ thuật Phần mềm

Giảng viên hướng dẫn:

TS. Bùi Văn Hiệu

TS. Đặng Văn Hiếu

Tóm tắt

Trong bối cảnh an ninh mạng hiện đại, các Trung tâm Điều hành An ninh mạng (SOC) đứng trước áp lực phải tự động hóa quá trình phân loại và phản hồi một khối lượng cảnh báo ngày một gia tăng; thế nhưng mọi giải pháp sẵn có đều buộc phải chấp nhận những đánh đổi đáng kể. Các công cụ tự động hóa truyền thống vận hành theo những kịch bản cứng nhắc, định sẵn, không thể suy xét các tình huống mơ hồ và cũng không thể lý giải cho quyết định của mình; trong khi việc đưa trực tiếp nhật ký thô vào một Mô hình Ngôn ngữ Lớn (LLM) lại quá chậm để đáp ứng thời gian thực, dễ bị thao túng ngay từ chính nội dung nhật ký, và sẽ vi phạm yêu cầu về chủ quyền dữ liệu nếu triển khai trên nền tảng đám mây. Nhằm khắc phục những hạn chế đó, luận văn đề xuất SENTINEL, một kiến trúc nhận thức hai tầng cho phát hiện và phản hồi mối đe dọa tự động. Tầng thứ nhất là một bộ lọc nhanh, tắt định, loại bỏ tức thời phần lớn lưu lượng vô hại và chỉ chuyển tiếp phần thiểu số thực sự khả nghi lên tầng thứ hai, một tác tử trí tuệ nhân tạo vận hành cục bộ, suy luận trên các nguồn tri thức an ninh chuẩn mực (kỹ thuật MITRE ATT&CK và hướng dẫn ứng phó sự cố của NIST) và hoạt động phía sau nhiều lớp rào chắn bảo vệ nhằm chống lại sự đánh lừa từ những đầu vào độc hại.

Qua đánh giá trên các bộ dữ liệu phát hiện xâm nhập tiêu chuẩn, SENTINEL cho thấy khả năng duy trì tính khả thi thực tiễn của suy luận bằng trí tuệ nhân tạo: bằng cách chỉ dành năng lực tính toán đắt đỏ này cho số ít cảnh báo thực sự cần đến, hệ thống giảm hơn 80% độ trễ phản hồi trung bình so với phương án chỉ sử dụng LLM. Hệ thống đồng thời chống chịu được các tấn công thao túng dựa trên nội dung, đưa ra những lý giải minh bạch và có thể kiểm chứng cho mỗi quyết định, và vận hành trọn vẹn trên phần cứng phổ thông tại chỗ mà không cần gửi dữ liệu ra bên ngoài. Nhìn chung, nghiên cứu khẳng định rằng sự kết hợp giữa một bộ lọc tắt định tốc độ cao và một tầng suy luận trí tuệ nhân tạo an toàn, minh bạch, triển khai cục bộ chính là một hướng tiếp cận thiết thực và đáng tin cậy cho bài toán tự động hóa phòng thủ mạng hiện đại.

Lời cảm ơn

Trước hết, tôi xin bày tỏ lòng biết ơn chân thành và sâu sắc nhất tới hai người thầy hướng dẫn khoa học của mình, TS. Bùi Văn Hiệu và TS. Đặng Văn Hiếu. Sự định hướng khoa học chuẩn xác, những góp ý chuyên môn sâu sắc cùng sự tận tâm và kiên nhẫn dịu dặt của quý thầy trong suốt chặng đường thực hiện đề tài chính là nền tảng vững chắc để tôi hoàn thành công trình nghiên cứu này một cách trọn vẹn.

Tôi cũng xin trân trọng gửi lời tri ân tới quý thầy cô và cán bộ của Viện Quản trị & Công nghệ FSB, Đại học FPT, những người đã trang bị cho tôi nền tảng tri thức học thuật quý báu và kiến tạo một môi trường học tập, nghiên cứu chuyên nghiệp, hiện đại, tạo mọi điều kiện thuận lợi cho học viên trong suốt quá trình theo học chương trình Thạc sĩ.

Đồng thời, tôi xin gửi lời cảm ơn sâu sắc tới Ban lãnh đạo cùng các đồng nghiệp tại Cục C12, Trung tâm Dữ liệu Quốc gia, nơi tôi đang công tác. Sự tạo điều kiện về thời gian, môi trường làm việc thực tiễn và những trao đổi chuyên môn quý giá đã tiếp thêm cho tôi nhiều động lực để hoàn thành tốt cả nhiệm vụ chuyên môn lẫn con đường học tập, nghiên cứu.

Cuối cùng, và cũng là điều thiêng liêng nhất, tôi xin dành trọn lòng tri ân tới gia đình thân yêu của mình, đặc biệt là người vợ hiền và con nhỏ. Sự hy sinh thầm lặng, lòng kiên nhẫn, sự thấu hiểu và nguồn động viên tinh thần không ngừng nghỉ của gia đình trong những tháng ngày tôi miệt mài với các đợt thực nghiệm kéo dài chính là điểm tựa lớn lao nhất, nâng bước tôi vững vàng trên hành trình chinh phục học vị Thạc sĩ.

Danh sách hình vẽ

Hình 1.	Kiến trúc tổng thể SENTINEL: luồng dữ liệu hai tầng và các cấu phần. (Nguồn: Tác giả)	20
Hình 2.	Luồng thực thi vận hành chi tiết trong pipeline SENTINEL. (Nguồn: Tác giả)	21

Danh sách bảng

Bảng 1.	Các mức lượng tử hóa cho mô hình Gemma-2-9B (xấp xỉ). (Nguồn: Tác giả)	15
Bảng 2.	Lỗi hồng nhận thức LLM và biện pháp giảm thiểu của SENTINEL. (Nguồn: Tác giả)	16
Bảng 3.	So sánh SENTINEL với các khung tác-tử-an-ninh gần đây (✓ có; ~ một phần; × không; – không áp dụng). (Nguồn: Tác giả)	18
Bảng 4.	Ma trận chuyển trạng thái của FSM tác tử nhận thức Tầng 2. (Nguồn: Tác giả)	24
Bảng 5.	Các mô hình truy xuất trong chiến lược tìm kiếm lai. (Nguồn: Tác giả)	25
Bảng 6.	Lược đồ cơ sở dữ liệu Bộ nhớ Đe dọa. (Nguồn: Tác giả)	26
Bảng 7.	Ảnh xạ đại diện các họ tấn công CSE-CIC-IDS2018 sang kỹ thuật MITRE ATT&CK và hành động mặc định. (Nguồn: Tác giả)	30
Bảng 8.	Phân loại nhị phân Tầng 1 trên Luồng Gộp (các sự kiện có nhãn CIC-IDS). (Nguồn: Tác giả)	31
Bảng 9.	Phân loại và giảm tải LLM của Cổng ML (LightGBM). Phân loại trên tập datatest 3,204 mẫu; giảm tải (Cấu hình G) trên tập ground_truth 1,250 mẫu. (Nguồn: Tác giả)	31
Bảng 10.	Phán xử Tầng 2 trên 800 sự kiện leo thang (bỏ qua Cổng ML; toàn pipeline theo từng sự kiện). (Nguồn: Tác giả)	32
Bảng 11.	Phát hiện APT đa giai đoạn nổi lên trên chuỗi DAPT2020 (bộ nhớ sạch). (Nguồn: Tác giả)	33
Bảng 12.	Đường biên phát hiện zero-day phân cấp theo độ lệch đơn-đặc-trưng (chỉ Tầng 1, $n = 210$ /mức). (Nguồn: Tác giả)	34
Bảng 13.	Ablation cân bằng có kiểm soát (150 benign + 150 tấn công). Baseline LLM thuần gắn cờ quá đà; các cấu hình có cổng (C–F) cho phán quyết giống hệt. (Nguồn: Tác giả)	35
Bảng 14.	Độ nhạy ngưỡng Welford trên luồng gộp thực (chỉ Tầng 1). (Nguồn: Tác giả)	35
Bảng 15.	Tỷ lệ chặn của lớp rào chắn tĩnh trên bộ 120 payload. (Nguồn: Tác giả)	36
Bảng 16.	Chất lượng suy luận LLM-làm-Trọng-tài chéo họ (trọng tài Llama-3-8B, tác tử Gemma-2-9B, $n = 908$, thang 1–5). (Nguồn: Tác giả) . .	37
Bảng 17.	Kết quả hợp nhất trên năm chiều đánh giá. (Nguồn: Tác giả)	38

Danh mục các từ viết tắt

Từ viết tắt	Định nghĩa đầy đủ
AI	Artificial Intelligence (Trí tuệ nhân tạo)
APT	Advanced Persistent Threat (Mối đe dọa thường trực nâng cao)
C2	Command and Control (Chỉ huy và điều khiển)
CNN	Convolutional Neural Network (Mạng nơ-ron tích chập)
CPU	Central Processing Unit (Bộ vi xử lý trung tâm)
CSV	Comma-Separated Values (Định dạng dữ liệu phân tách bằng dấu phẩy)
CTI	Cyber Threat Intelligence (Tình báo mối đe dọa mạng)
CVE	Common Vulnerabilities and Exposures (Danh sách lỗ hổng bảo mật phổ biến)
DAG	Directed Acyclic Graph (Đồ thị có hướng không chu trình)
DAPT	Dynamic/Delayed Advanced Persistent Threat (Tấn công APT động/trễ)
DL	Deep Learning (Học sâu)
DoS	Denial of Service (Từ chối dịch vụ)
EDR	Endpoint Detection and Response (Phát hiện và phản hồi điểm cuối)
FAISS	Facebook AI Similarity Search (Tìm kiếm tương đồng AI của Facebook)
FSM	Finite State Machine (Máy trạng thái hữu hạn)
GGUF	GPT-Generated Unified Format (Định dạng hợp nhất do GPT tạo ra)
GPU	Graphics Processing Unit (Bộ xử lý đồ họa)
HITL	Human-in-the-Loop (Con người trong vòng lặp)
HMAC	Hash-based Message Authentication Code (Mã xác thực thông báo dựa trên hàm băm)
IDS	Intrusion Detection System (Hệ thống phát hiện xâm nhập)
IOC	Indicator of Compromise (Chỉ thị xâm nhập)
IP	Internet Protocol (Giao thức mạng Internet)
IPS	Intrusion Prevention System (Hệ thống ngăn ngừa xâm nhập)
JSON	JavaScript Object Notation (Định dạng đối tượng JavaScript)
LLM	Large Language Model (Mô hình ngôn ngữ lớn)
LRU	Least Recently Used (Ít sử dụng gần đây nhất)
LSTM	Long Short-Term Memory (Mạng bộ nhớ ngắn-dài hạn)

MAS	Multi-Agent System (Hệ thống đa tác tử)
ML	Machine Learning (Học máy)
NGFW	Next-Generation Firewall (Tường lửa thế hệ tiếp theo)
NIST	National Institute of Standards and Technology (Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ)
OWASP	Open Web Application Security Project (Dự án bảo mật ứng dụng web mở)
PCAP	Packet Capture (Dữ liệu bắt gói tin)
RAG	Retrieval-Augmented Generation (Sinh văn bản tăng cường truy xuất)
RAGAS	Retrieval Augmented Generation Assessment (Khung đánh giá chất lượng sinh tăng cường truy xuất)
RAM	Random Access Memory (Bộ nhớ truy cập ngẫu nhiên)
RBA	Runbook Automation (Tự động hóa kịch bản chạy)
RCE	Remote Code Execution (Thực thi mã từ xa)
RRF	Reciprocal Rank Fusion (Tổng hợp xếp hạng nghịch đảo)
SHA	Secure Hash Algorithm (Thuật toán băm an toàn)
SIEM	Security Information and Event Management (Quản lý thông tin và sự kiện an ninh)
SOC	Security Operations Center (Trung tâm điều hành an ninh mạng)
SQLi	SQL Injection (Tấn công tiêm lệnh SQL)
SSTI	Server-Side Template Injection (Tấn công tiêm khuôn mẫu máy chủ)
SVM	Support Vector Machine (Máy vector hỗ trợ)
TTP	Tactics, Techniques, and Procedures (Chiến thuật, kỹ thuật và quy trình)
TTL	Time to Live (Thời gian tồn tại)
URL	Uniform Resource Locator (Đường dẫn tài nguyên thống nhất)
VRAM	Video Random Access Memory (Bộ nhớ truy cập ngẫu nhiên video)
WAF	Web Application Firewall (Tường lửa ứng dụng web)
XSS	Cross-Site Scripting (Tấn công kịch bản chéo trang)

Mục lục

Tóm tắt	1
Lời cảm ơn	2
Danh mục các từ viết tắt	5
1 Giới thiệu	9
1.1 Bối cảnh và Động lực	9
1.2 Mục tiêu Nghiên cứu	10
1.3 Câu hỏi Nghiên cứu	10
1.4 Phạm vi và Đối tượng Nghiên cứu	11
1.5 Phương pháp Nghiên cứu	12
1.6 Đóng góp của Luận văn	12
1.7 Cấu trúc của Luận văn	13
2 Cơ sở Lý thuyết và Tổng quan Nghiên cứu	14
2.1 SOC và Nút thắt Nhận thức	14
2.2 LLM Cục bộ và Toán học của Lượng tử hóa	14
2.3 AI Tác tử và Mô hình Đồ thị Trạng thái	15
2.4 Sinh Tăng cường Truy xuất và Tìm kiếm Lại	15
2.5 Lỗi hổng Nhận thức LLM và Vector Đối kháng	15
2.6 Phát hiện Dị biệt Thống kê Trực tuyến: Thuật toán Welford	16
2.7 Nghiên cứu Liên quan: AI Tác tử cho Vận hành An ninh	17
2.8 Tóm tắt Chương	18
3 Thiết kế Hệ thống và Triển khai Kỹ thuật	19
3.1 Tổng quan về Kiến trúc Nhận thức Hai tầng	19
3.2 Định vị trong Ngăn xếp SOC Hiện hữu	22
3.3 Tầng 1: Bộ lọc Tốc độ Đường truyền Phi trạng thái (RuleEngine & Welford)	22
3.4 Cổng ML: Giảm tải Tầng 1 bằng Học máy	23
3.5 Tầng 2: Tác tử Nhận thức Có trạng thái LangGraph	23
3.6 Cơ chế Dual-RAG và Bộ nhớ Ngữ nghĩa	25
3.7 Bộ nhớ Đe dọa và Liên kết Chiến dịch APT	25
3.8 Rào chắn Bảo mật AI và Lớp Đóng gói	26
3.9 Tính toàn vẹn Dữ liệu và Bảo vệ HMAC	26
3.10 Dashboard, Triển khai và Khả năng Mở rộng	27
3.11 Tóm tắt Chương	27
4 Thực nghiệm và Đánh giá	29
4.1 Môi trường Thực nghiệm và Bộ Dữ liệu	29

4.2	Chỉ số 5D và Thiết kế Ablation	30
4.3	Độ chính xác Phân loại trên Luồng Gộp	31
4.4	Cổng ML: Giảm tải Tầng 1 bằng Học máy	31
4.5	Phản xử Ca Leo thang tại Tầng 2	32
4.6	Liên kết APT Đa ngày Nổi lên (Nền tảng)	33
4.7	Escalation Zero-Day (Không chữ ký) qua Điểm Welford	33
4.8	Ablation: Đánh đổi Độ trễ Hai tầng và So sánh Cân bằng	34
4.9	Đánh giá Kháng Đối kháng (Bảo mật)	36
4.10	Tính toàn vẹn và Chất lượng Suy luận (LLM-làm-Trọng-tài)	36
4.11	Độ bền Vận hành	37
4.12	Lớp Ánh xạ ATT&CK Có cấu trúc	37
4.13	Tổng hợp Kết quả 5D	38
4.14	Tóm tắt Chương	38
5	Kết luận và Hướng phát triển	39
5.1	Tổng hợp Kết quả Nghiên cứu Đạt được	39
5.2	Đóng góp Khoa học và Thực tiễn	40
5.3	Các Giới hạn Hiện hữu	40
5.4	Hướng Phát triển Tương lai	42
	Tài liệu tham khảo	44

Chương 1

Giới thiệu

Chương này thiết lập bối cảnh nghiên cứu cho SENTINEL, một kiến trúc nhận thức hai tầng tự động hóa phát hiện và phản hồi sự cố trong các Trung tâm Điều hành An ninh (SOC) hiện đại. Bằng việc phân tích nạn bội thực cảnh báo, sự mù lòa của hệ dựa-luật, và các giới hạn tính toán của Mô hình Ngôn ngữ Lớn (LLM), chương trình bày thiết kế và xác thực một pipeline phát hiện lai bảo mật, phác họa mục tiêu, câu hỏi nghiên cứu, phạm vi, và phương pháp định lượng.

1.1 Bối cảnh và Động lực

Mạng doanh nghiệp hiện đại đã trở nên cloud-native và xộp, mở rộng mạnh bề mặt tấn công. Kẻ tấn công trải từ malware phổ thông tới các chiến dịch đa pha tinh vi [2], nhưng đều hội tụ về một nút thắt: khối lượng telemetry khổng lồ mà người phòng thủ phải sàng lọc. Các SOC hợp nhất log từ NGFW, IDS/IPS, EDR vào nền tảng SIEM tập trung [3] để chuẩn hóa và liên kết. Việc lọc tuyến đầu như vậy (IDS/IPS tốc độ dây, thu nạp ở rìa) là tất định và cứng nhắc: nó cắt khối lượng nhưng không thể suy luận về một cảnh báo mơ hồ hay giải thích một phán quyết, nên tốc độ telemetry vẫn tạo ra một “Nghịch lý Dữ liệu Lớn” [4] đẩy phán đoán ngữ cảnh về lại analyst con người. Điều này biểu hiện thành khủng hoảng *một mỗi cảnh báo* nghiêm trọng: analyst bị ngập bởi thông báo độ-tin-cậy-thấp, phần lớn báo giả [6], làm tăng mạnh nguy cơ bỏ sót xâm nhập thật.

Hai khoảng trống nữa trầm trọng thêm. Thứ nhất, các bộ lọc neo-chữ-ký [2] mù cấu trúc với biến thể mới (zero-day, malware đa hình) né luật tĩnh bằng thay đổi payload nhỏ, bộc lộ nhu cầu một tín hiệu ngoại-lai-thống-kê độc lập chữ ký. Thứ hai, lấy mẫu log vì chi phí cắt đứt liên kết thời gian cần để tái dựng chuỗi chậm-âm-thầm [5]. SOAR thông thường cũng không lấp khoảng trống suy luận—nó chạy playbook cứng định sẵn không thể suy luận hay giải thích cảnh báo ngoài kịch bản [7].

LLM hứa hẹn đúng khả năng suy luận ngữ cảnh còn thiếu này, nhưng dùng trực tiếp trong SOC vấp một nghịch lý tích hợp. Độ trễ suy luận của chúng quá lớn cho log tốc độ cao

do chi phí bậc hai của self-attention [20]; giao diện ngôn ngữ tự nhiên phối chúng trước injection nền-log, nơi payload nhúng trong trường như User-Agent chiếm quyền suy luận nếu không cách ly nghiêm ngặt [11]; và trong môi trường air-gapped hay Zero-Trust [35] telemetry không thể rời đi tới mô hình đám mây, nên tầng suy luận phải chạy cục bộ. Để giải quyết, SENTINEL đề xuất mô hình hai tầng: một bộ lọc Tầng 1 phi trạng thái ở tốc độ đường truyền, một cổng học giảm tải phần lớn ca leo thang chắc chắn, và một tầng AI Tác tử Tầng 2 an toàn, host cục bộ thực hiện suy luận cách ly nhận thức. Như sản phẩm phụ, thiết kế có trạng thái cũng bảo toàn chuỗi chậm-âm-thầm và gắn cờ ngoại lai không chữ ký—coi là năng lực nền tảng, không phải kết quả trung tâm.

1.2 Mục tiêu Nghiên cứu

Mục tiêu tổng quát là thiết kế, triển khai và đánh giá định lượng kiến trúc nhận thức hai tầng SENTINEL kết hợp lọc thống kê độ-trễ-thấp với suy luận tác tử an toàn, nhận-thức-ngữ-cảnh. Ba mục tiêu cụ thể dưới đây *xây* artifact, và ba câu hỏi nghiên cứu ở Mục 1.3 *đánh giá* chính artifact đó theo quan hệ một-đối-một: MT_i tạo ra cấu phần mà RQ_i chất vấn.

MT1 — Tầng hấp thụ lưu lượng (đối ứng RQ1). Xây một *chuỗi lọc hai chặng*: bộ lọc tắt định tốc độ đường truyền triển khai thuật toán Welford trực tuyến cho phương sai và Z-score lẫn $O(1)$, nối tiếp một *cổng phân loại học máy* (LightGBM) tự quyết phần lớn ca leo thang. Mục tiêu không phải đạt độ chính xác phân loại cao nhất, mà là *giảm thiểu số lần phải gọi suy luận LLM* với mức suy giảm độ chính xác định lượng được.

MT2 — Đóng gói an toàn cho LLM (đối ứng RQ2). Thiết kế các cơ chế phòng thủ *tất định, theo cấu trúc* cho việc tích hợp một LLM lượng tử hóa cục bộ: Đóng gói Dữ liệu Phân định bằng nonce mật mã, rào chắn đồng thuận hai tầng, làm sạch đầu ra, và chuỗi audit HMAC—sao cho bảo đảm cốt lõi đúng *theo cấu trúc* chứ không theo huấn luyện, và phân định rõ vector nào thuộc lớp phòng thủ nào.

MT3 — Trạng thái, bộ nhớ và nổi nền (đối ứng RQ3). Dựng một tác tử nhận thức *có trạng thái* trên LangGraph, kết hợp một Bộ nhớ Đa dạng bền vững với một hệ truy xuất tri thức kép hợp nhất MITRE ATT&CK và NIST SP 800-61r2 bằng Reciprocal Rank Fusion—nhằm nổi nền phần *quy kết* và *biện minh* của phán quyết, và cho phép liên kết chiến dịch đa ngày nổi lên từ trạng thái tích lũy.

1.3 Câu hỏi Nghiên cứu

Ba câu hỏi dẫn dắt kiểm chứng thực nghiệm, mỗi câu ứng với một đóng góp nêu ở Mục 1.6.

RQ1 (kinh tế học của tầng lọc). Một pipeline lai—tầng lọc tắt định $O(1)$ trên baseline thông kê trực tuyến, nối tiếp một cổng phân loại học máy—hấp thụ được bao nhiêu phần lưu lượng SOC ở tốc độ đường truyền trước khi phải viện tới suy luận LLM cục bộ nhiều giây, và *cái giá phải trả* về độ chính xác phát hiện là bao nhiêu? Câu hỏi đặt ở dạng đánh đổi vì đóng góp kiến trúc không nằm ở việc phát hiện tốt hơn một bộ phân loại đơn lẻ, mà ở việc khiến một mô hình cục bộ nhiều giây trở nên khả thi về vận hành.

RQ2 (phòng thủ nằm ở đâu trong kiến trúc). Phòng thủ chống tiêm nhiễm nền-log đặt ở đâu thì hiệu quả: ở lớp lọc mẫu tắt định, hay ở Đóng gói Dữ liệu Phân định cộng rào chắn đồng thuận hai tầng? Mỗi lớp vô hiệu được *nhóm vector đối kháng* nào, và ranh giới năng lực giữa chúng nằm ở đâu?

RQ3 (trạng thái mang lại năng lực gì). Việc thay Tự động hóa Runbook cứng bằng một tác tử *có trạng thái*—với bộ nhớ đe dọa bền vững và truy xuất tri thức kép hợp nhất bằng Reciprocal Rank Fusion—mang lại năng lực gì mà một tầng phi trạng thái không thể có? Đo bằng (a) khả năng liên kết chiến dịch đa ngày *nổi lên* và (b) độ chính xác quy kết kỹ thuật MITRE ATT&CK cùng độ trung thành của biện minh sinh ra.

Ghi chú về dụng cụ đo. RQ3 cố ý *không* dùng độ chính xác phân loại nhị phân làm thước đo cho đóng góp của truy xuất tri thức. Ngữ cảnh truy xuất tác động tới *quy kết* và *biện minh* của một phán quyết, không tác động tới câu hỏi nhị phân “có phải tấn công hay không”; dùng độ chính xác phân loại ở đây là sai dụng cụ và không thể phân biệt được các cấu hình truy xuất. Tương tự, luận văn không tuyên bố tầng LLM là một *bộ phân loại*: bằng chứng ở Chương 4 định vị nó là một lưới an toàn thiên về độ phủ, và giới hạn này được nêu thẳng ở Mục 5.3.

1.4 Phạm vi và Đối tượng Nghiên cứu

Đối tượng nghiên cứu: chính là kiến trúc nhận thức hai tầng—cơ chế mà một bộ lọc Tầng 1 tắt định phi trạng thái ở tốc độ đường truyền được kết hợp với một tầng tác tử Tầng 2 có trạng thái host cục bộ để tự động hóa phát hiện và phản hồi SOC. Điều này bao hàm các cấu phần: telemetry flow tốc độ cao ở OSI Lớp 3–4 (five-tuple NetFlow và đặc trưng flow CICFlowMeter, với metadata PCAP thay vì soi payload sâu); điều phối tác tử có trạng thái (LangGraph); LLM lượng tử hóa cục bộ cho suy luận air-gapped; và các vector đối kháng injection nền-log, buôn lậu delimiter, và đầu độc kho tri thức. **Phạm vi:** đánh giá giới hạn ở CSE-CIC-IDS2018 [1] cho tấn công tổng quát và DAPT2020 [29] cho APT đa giai đoạn, với zero-day mô phỏng bằng cách tiêm độ lệch Welford cực trị vào luồng benign. Mô hình là *Gemma-2-9B-IT* cục bộ lượng tử hóa Q6_K qua `llama.cpp` trên một GPU phổ thông, đảm bảo chủ quyền dữ liệu. Hành động tự chủ giới hạn ở sinh chính sách tường lửa, báo cáo, và pháp y, loại trừ ngắt kết nối vật lý tự động.

1.5 Phương pháp Nghiên cứu

Luận văn theo hướng Nghiên cứu Khoa học Thiết kế dưới lập luận suy diễn, định lượng: nó tạo tri thức bằng cách xây một artifact hoạt động (SENTINEL) và đánh giá nó trước một bài toán vận hành thực, chốt mọi khẳng định bằng đo lường. Nó lập luận theo ba cách: thống kê (tách lưu lượng thường khỏi dị biệt), logic (cấu trúc quy trình quyết định của tác tử), và đối kháng (thử độ bền trước thao túng). Cụ thể, hệ được triển khai như một bản mẫu hai tầng, được thử qua các thí nghiệm đầu-cuối phát lại dữ liệu lưu trữ và lưu lượng trực tiếp dưới đầu vào đối kháng, và được đánh giá trên khung năm chiều (độ chính xác, hiệu suất, bảo mật, tính giải thích, tính toàn vẹn). Ablation có kiểm soát cô lập đóng góp từng cấu phần, và kiểm định phi tham số xác nhận các khác biệt là có ý nghĩa. Nghiên cứu dùng dữ liệu định lượng (đo lường số và đầu ra như độ chính xác, độ trễ) và dữ liệu định tính (giải thích ngôn ngữ tự nhiên của mô hình), cái sau được chấm qua một khung tự động [30] và một trọng tài LLM chéo họ độc lập để chất lượng suy luận cũng đánh giá được trên cơ sở so sánh.

1.6 Đóng góp của Luận văn

Đóng góp gồm ba phần, mỗi phần nêu ở đúng phạm vi bằng chứng cho phép. **Về kiến trúc**, công trình kiểm chứng một pipeline hai tầng khiến một LLM host cục bộ nhiều giây khả thi vận hành trong SOC. Đóng góp không phải một tiền lọc cô lập mà là sự *kết hợp*: một cổng thống kê $O(1)$ phi trạng thái và một cổng học giảm-tải hấp thụ lưu lượng lành tính và phân-loại-chắc-chắn ở tốc độ đường truyền và bảo vệ mạng tất định, trong khi tầng nhận thức đắt đỏ được gọi bất đồng bộ và chỉ trên thiểu số mơ hồ. **Về bảo mật AI**, nó đóng góp một phòng thủ tất định, cấu trúc chống injection nền-log—Đóng gói Dữ liệu Phân định, một rào chắn đồng thuận Tầng 1/Tầng 2, và một chuỗi audit HMAC—mà bảo đảm lỗi đúng theo cấu trúc chứ không theo huấn luyện: một rào chắn đồng thuận luật-cố-định không thể bị thuyết phục hạ cấp, dù payload đã gặp hay chưa. **Về điều phối**, nó thay Tự động hóa Runbook cứng bằng một tác tử có trạng thái mà luồng là một đồ thị trạng thái không-chu-trình, không-công-cụ trên một mô hình lượng tử hóa cục bộ, cho một tầng vừa thích ứng vừa tái lập và kiểm toán pháp y được dưới ràng buộc chủ quyền dữ liệu. Hai năng lực nữa mà kiến trúc cho phép—escalation dị biệt không chữ ký và liên kết đa ngày nổi lên—được nêu như bằng chứng khái niệm giới hạn trung thực, với việc trưởng thành sản xuất dời sang tương lai.

1.7 Cấu trúc của Luận văn

Chương 2 thiết lập nền tảng lý thuyết (lượng tử hóa LLM, mô hình đồ thị trạng thái, RAG, thống kê trực tuyến) và tổng quan nghiên cứu tác-tử-an-ninh liên quan. Chương 3 trình bày thiết kế hệ thống: bộ lọc hai tầng, Cổng ML, FSM tác tử có trạng thái, truy xuất lai, rào chắn, dashboard, và triển khai. Chương 4 trình bày thí nghiệm, ablation, và kiểm chứng thống kê. Chương 5 kết luận với các phát hiện, giới hạn, và hướng tương lai.

Chương 2

Cơ sở Lý thuyết và Tổng quan Nghiên cứu

Chương này thiết lập nền tảng lý thuyết cho SENTINEL, bắt đầu từ nút thắt nhận thức tại các Trung tâm Điều hành An ninh (SOC) hiện đại, rồi tới LLM cục bộ và lượng tử hóa, AI Tác tử dựa trên đồ thị trạng thái, Sinh Tăng cường Truy xuất (RAG), các lỗ hổng AI đối kháng, phát hiện dị biệt thống kê trực tuyến, và các nghiên cứu tác-tử-an-ninh liên quan.

2.1 SOC và Nút thắt Nhận thức

Các SOC hiện đại hợp nhất telemetry đa dạng (NGFW, EDR, IDS/IPS) vào nền tảng SIEM tập trung [3] để nhận diện đe dọa và leo thang sự cố tới analyst. Tuy nhiên, sự dịch chuyển sang hạ tầng cloud-native gây bùng nổ dữ liệu log [4], dẫn tới khủng hoảng *một mỗi cảnh báo*: analyst Tầng 1 thường bị ngập bởi hàng nghìn cảnh báo mỗi ngày, phần lớn là báo giả, và các trận lụt cảnh báo liên tục làm cạn kiệt nguồn lực chú ý, làm tăng có hệ thống xác suất bỏ sót đe dọa nghiêm trọng [6]. Trầm trọng thêm, các Đe dọa Thường trực Nâng cao (APT) dùng chiến thuật ẩn mình, kéo dài mà các khung dựa-luật phi trạng thái không thể liên kết qua các chân trời thời gian dài [5].

2.2 LLM Cục bộ và Toán học của Lượng tử hóa

LLM dựa trên Transformer mang lại tự động hóa hứa hẹn: cơ chế self-attention cân mọi token với tất cả token khác song song [20], nắm bắt các phụ thuộc tầm xa cần thiết để liên kết sự kiện qua một luồng log dài. Tuy nhiên, yêu cầu chủ quyền dữ liệu cấm truyền telemetry nhạy cảm tới endpoint đám mây ngoài theo nguyên tắc zero-trust [35], buộc dùng LLM *cục bộ* trong môi trường air-gapped. Chạy mô hình tỷ tham số cục bộ bị giới hạn bộ nhớ: một mô hình 9B như *Gemma-2-9B-IT* ở FP16 cần ≈ 18 GB VRAM. Lượng tử hóa ánh xạ lại các trọng số liên tục độ-chính-xác-cao lên lưới số nguyên bit-thấp thô hơn, đánh đổi mất mát độ chính xác có kiểm soát lấy tiết kiệm bộ nhớ lớn [21]. Qua GGUF và chuẩn Q6_K trong `llama.cpp`, dung lượng giảm còn $\approx 7-8$ GB (giảm hơn 50%) với suy luận

gần-không-mất-mát (Bảng 1), cho phép suy luận trên phần cứng phổ thông.

Bảng 1. Các mức lượng tử hóa cho mô hình Gemma-2-9B (xấp xỉ). (Nguồn: Tác giả)

Định dạng	Bit / trọng số	VRAM	Chất lượng
FP16 (cơ sở)	16	≈18 GB	Tham chiếu
Q6_K (luận văn)	≈6.6	≈7–8 GB	Gần-không-mất
Q4_K_M	≈4.5	≈5–6 GB	Suy giảm nhẹ

2.3 AI Tác tử và Mô hình Đồ thị Trạng thái

An ninh tự động đang dịch từ Tự động hóa Runbook (RBA) cứng sang AI Tác tử tự chủ [7]. RBA dựa vào script định sẵn cho xử lý cảnh báo tuyến tính—hiệu quả nhưng mù cấu trúc với điều kiện zero-day và định dạng đa hình. Hệ tác tử thể hiện tự chủ nhận thức (tự phản tỉnh, lập kế hoạch nhiều bước, định tuyến thích ứng), điều chỉnh phân tích theo phát hiện trung gian. Các tác tử này được mô hình hóa như đồ thị có hướng có trạng thái hoạt động như máy trạng thái hữu hạn [10], nơi nút là hành động tính toán/nhận thức và cạnh điều kiện ép định tuyến động theo đầu ra nút cha. Điều phối có trạng thái cho phép tác tử giữ bộ nhớ làm việc qua các sự kiện; dù mô hình này cũng cho phép tái phân tích chu trình trong một sự kiện, SENTINEL có chủ đích chọn duyệt *không chu trình* theo từng sự kiện để tắt định và kiểm toán được, lưu trạng thái xuyên-sự-kiện trong Bộ nhớ Đe dọa thay vì lặp.

2.4 Sinh Tăng cường Truy xuất và Tìm kiếm Lai

Hạn chế chính của LLM là ảo giác sự thật, rủi ro nghiêm trọng gây cấu hình sai trong SOC tự động. RAG chống điều này bằng cách điều kiện hóa mỗi phản hồi trên các đoạn truy xuất tươi từ một kho có thẩm quyền thay vì chỉ bộ nhớ tham số [9], thu hẹp không gian cho các khẳng định vô căn cứ. RAG hiện đại dùng chiến lược *lai*: tìm kiếm vector dày với mô hình nhúng (all-MiniLM-L6-v2) [27] và tương đồng cosine FAISS [22] nắm nghĩa ngữ nghĩa dù khác từ khóa, trong khi BM25 thưa [23] khớp định danh kỹ thuật (mã CVE, IP) qua trọng số TF-IDF. Reciprocal Rank Fusion [13] hợp nhất hai danh sách hạng thành một kết quả độ-chính-xác-cao bằng cách cân ngữ nghĩa dày với trọng số từ khóa thưa.

2.5 Lỗ hổng Nhận thức LLM và Vector Đối kháng

Triển khai LLM làm engine suy luận lõi tạo ra lỗ hổng mới. Vì LLM xử lý ngôn ngữ tự nhiên không có phân tách code-và-data lúc biên dịch, chúng dễ bị chiếm quyền chỉ dẫn [11].

Vector liên quan nhất là *injection nền-log* [14]: kẻ tấn công nhúng payload lệnh vào trường telemetry (vd User-Agent), và khi LLM xử lý các log này nó có thể thực thi chỉ dẫn nhúng, vượt kiểm soát. Nghiên cứu gần đây hình thức hóa các tấn công này thành phân loại bốn lớp [14]: *Ghi đè Trực tiếp* (S1) chỉ thị mô hình bỏ qua chỉ dẫn trước; *Chiếm quyền Persona* (S2) ép một persona không giới hạn; *Thao túng Ngữ cảnh* (S3) bịa siêu-dữ-liệu ủy quyền (vd “đã duyệt trước”); và *Payload Che giấu* (S4) giấu chỉ dẫn qua mã hóa Base64/hex/URL hoặc homoglyph để né bộ lọc regex. Vì các trường này do kẻ tấn công kiểm soát nhưng không phân biệt được về cấu trúc với bằng chứng hợp lệ, một LLM một-lượt không thể tách data khỏi chỉ dẫn một cách đáng tin—trực tiếp thúc đẩy thiết kế rào chắn phân lớp ở Chương 3 (Bảng 2).

Bảng 2. Lỗ hổng nhận thức LLM và biện pháp giảm thiểu của SENTINEL. (Nguồn: Tác giả)

Vector tấn công	Cơ chế đe dọa	Biện pháp
Injection Prompt Trực tiếp	Payload chiếm quyền trong đầu vào	Bộ lọc regex, prompt cấu trúc
Injection Nền-log	Chỉ dẫn trong trường log (User-Agent)	Đóng gói Phân định w/ token ngẫu nhiên
Vượt Mã hóa	Che giấu Base64/Hex/URL	Giải mã & chuẩn hóa nhiều lớp
Buôn lậu Delimiter	Mốc điều khiển kết thúc phạm vi data	Làm sạch delimiter, ngăn sách token
Đầu độc Ngữ nghĩa	Tài liệu giả trong vector DB	Checksum SHA-256 + nguồn gốc

2.6 Phát hiện Dị biệt Thống kê Trực tuyến: Thuật toán Welford

Vì độ phức tạp bậc hai của attention ngăn LLM phân tích luồng thô ở tốc độ đường truyền, một bộ tiền lọc $O(1)$ là cần thiết. Tính baseline lẫn trên luồng liên tục cần thống kê trực tuyến ổn định số học như thuật toán Welford [8], theo dõi trung bình và phương sai lẫn mà không tích lũy sai số dấu phẩy động:

$$\mu_k = \mu_{k-1} + \frac{x_k - \mu_{k-1}}{k}, \tag{2.1}$$

$$M_{2,k} = M_{2,k-1} + (x_k - \mu_{k-1})(x_k - \mu_k), \tag{2.2}$$

$$\sigma_k^2 = \frac{M_{2,k}}{k - 1}. \tag{2.3}$$

Duy trì các tham số này với bộ nhớ hằng, hệ tính Z-score chuẩn hóa cho mỗi gói, loại nhanh lưu lượng lành tính trong khi bảo toàn chuỗi sự kiện của tấn công chậm-âm-thầm. Để kiểm

chúng phát hiện không chữ ký, một mô hình zero-day *real-derived* tách một luồng benign thật và đẩy một thống kê tối biên cực trị, ép một Z-score lớn mô phỏng ngoại lai chưa biết và được leo thang lên Tầng 2.

2.7 Nghiên cứu Liên quan: AI Tác tử cho Vận hành An ninh

Phát hiện đe dọa tự động tiến hóa qua nhiều đợt. Phát hiện xâm nhập cổ điển dùng học máy (Random Forest, SVM) hoặc học sâu (LSTM, CNN) [2]; chính xác nhưng hoạt động như “hộp đen” không giải thích được. LLM sau đó mở một mặt trận nghiên cứu rộng khắp an ninh mạng, như các khảo sát hệ thống gần đây tổng hợp [17], thúc đẩy dịch chuyển tới hệ có thể giải thích và hành động. Gần nhất với luận văn này là một đợt khung tác tử ghép suy luận LLM với truy xuất: CyberRAG [15] điều phối các bộ phân loại tinh chỉnh qua vòng truy xuất-và-suy-luận lặp cho gán nhãn tấn công web; LanG [18] đề xuất một nền tảng LangGraph nhận thức-quản-trị hợp nhất liên kết, sinh luật LLM, và tái dựng tấn công với chốt HITL; Sahay và cộng sự [19] ghép autoencoder và học tăng cường sâu cho triage với một LLM cho sẵn đe dọa trong SIEM; và các thiết kế đa-tác-tử như AutoBnB-RAG [16] mở rộng hợp tác tăng-cường-truy-xuất tới ứng phó sự cố. Về phía đối kháng, Pandey và Bhujang [14] hình thức hóa đe dọa injection nền-log (phân loại S1–S4) và chứng minh tính hiệu quả của nó. Các hệ này thiết lập giá trị của tự động hóa tác tử nổi-nền-truy-xuất, và *phần lớn đã có* một tiền lọc và, trong một số trường hợp, một rào chắn đầu vào; nơi họ xử lý injection, họ thường dựa vào một bộ phân loại ngữ nghĩa *học* mà một payload mới vẫn có thể né.

Trên nền đó, SENTINEL khác biệt theo ba trục thiết kế có chủ đích chứ không phải một tính năng thiếu đơn lẻ. Thứ nhất, cổng Tầng 1 của nó là thống kê Welford $O(1)$ không-cần-huấn-luyện (cùng một Cổng *LightGBM* học cho dải leo thang) chứ không phải một tiền lọc cần tái huấn luyện liên tục. Thứ hai, nó thay bộ phân loại injection học bằng cách ly *tất định*, cấu trúc: Đóng gói Dữ liệu Phân định, rào chắn đồng thuận, và chuỗi audit HMAC. Thứ ba, khác các tác tử gọi-công-cụ với vòng lặp, nó dùng điều phối không-chu-trình, không-công-cụ chạy hoàn toàn trên một mô hình lượng tử hóa cục bộ, ưu tiên tất định, kiểm toán được, và chủ quyền dữ liệu. Bảng 3 định vị SENTINEL theo các năng lực liên quan nhất tới một engine SOC triển khai được, được củng cố bảo mật.

SENTINEL do đó nổi bật không bởi một cấu phần đơn lẻ mà bởi sự tích hợp: một bộ lọc Tầng 1 tất định và cổng học hấp thụ phần lớn tốc-độ-cao ở tốc độ đường truyền, trong khi một tác tử Tầng 2 cách ly nhận thức suy luận sau rào chắn mật mã, trực tiếp giải quyết đánh đổi độ-trễ-bảo-mật mà các khung khảo sát để ngỏ.

Bảng 3. So sánh SENTINEL với các khung tác-tử-an-ninh gần đây (✓ có; ~ một phần; × không; – không áp dụng). (Nguồn: Tác giả)

Năng lực	SENTINEL	Cyber-RAG	LanG	Splunk-LLM	Watch-tower
Tiền lọc $O(1)$ tốc độ đường truyền	✓	×	×	~	–
Rào chắn chống injection tất định	✓	×	~	×	–
Suy luận cục bộ / air-gapped	✓	~	~	×	–
Liên kết APT đa ngày	✓	×	✓	~	–
RAG lai dày+thưa (RRF)	✓	~	×	×	–
Audit HMAC chống giả mạo	✓	×	~	×	–

2.8 Tóm tắt Chương

Chương này đã thiết lập nền tảng của SENTINEL: nút thắt nhận thức SOC, lượng tử hóa LLM cục bộ, điều phối tác tử có trạng thái, RAG lai qua RRF, phân loại injection nền-log (S1–S4), và thuật toán Welford $O(1)$ cho phát hiện dị biệt không chữ ký. So sánh với các khung tác-tử-an-ninh gần đây định vị SENTINEL là hướng hợp nhất tiền-lọc thống kê tốc độ đường truyền, rào chắn chống injection tất định, chủ quyền dữ liệu cục bộ, và kiểm toán chống giả mạo. Chương 3 trình bày thiết kế kỹ thuật.

Chương 3

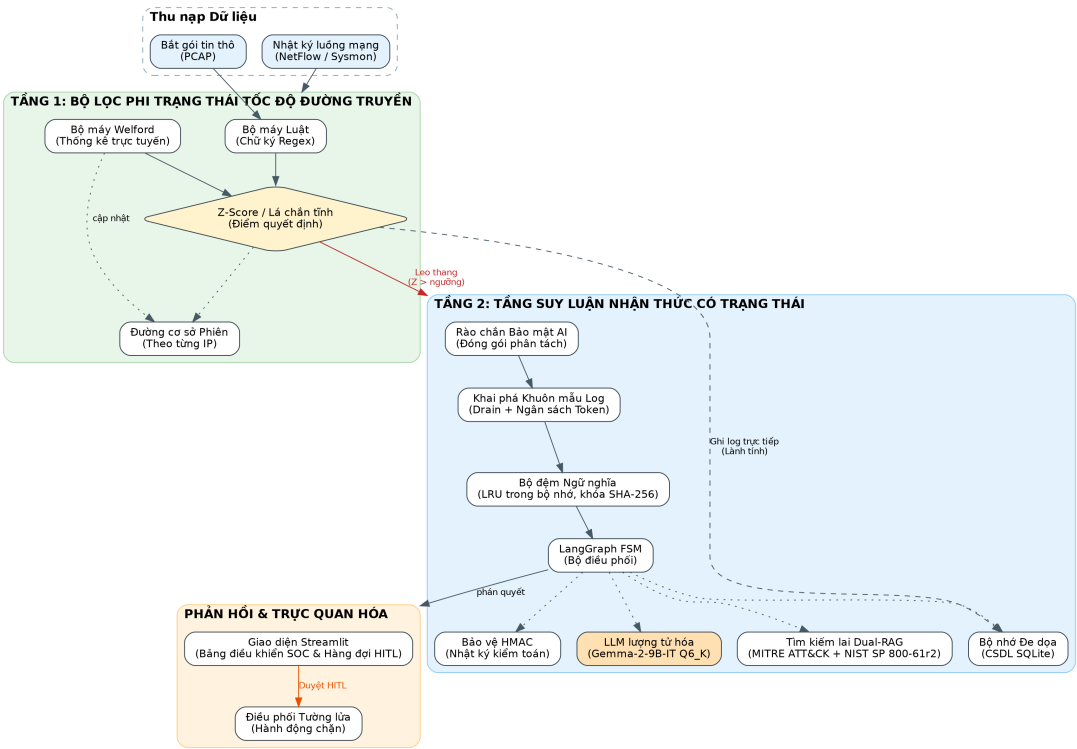
Thiết kế Hệ thống và Triển khai Kỹ thuật

Chương này trình bày kiến trúc, mô hình hóa toán học và triển khai của khung bảo mật nhận thức hai tầng SENTINEL: một quy trình phát hiện-và-phản hồi lại được thiết kế để san lấp khoảng cách giữa xử lý gói tin tốc độ đường truyền và suy luận LLM tốn tài nguyên, đồng thời thiết lập các rào chắn nhận thức cách ly LLM khỏi thao túng đối kháng. Chương bao quát sơ đồ khối hệ thống, bộ tiền lọc thống kê trực tuyến, Cổng ML, quy trình nhận thức dựa trên đồ thị trạng thái, truy xuất Dual-RAG, lược đồ Bộ nhớ Đe dọa, pipeline rào chắn, chuỗi audit HMAC, giao diện Streamlit và triển khai Docker.

3.1 Tổng quan về Kiến trúc Nhận thức Hai tầng

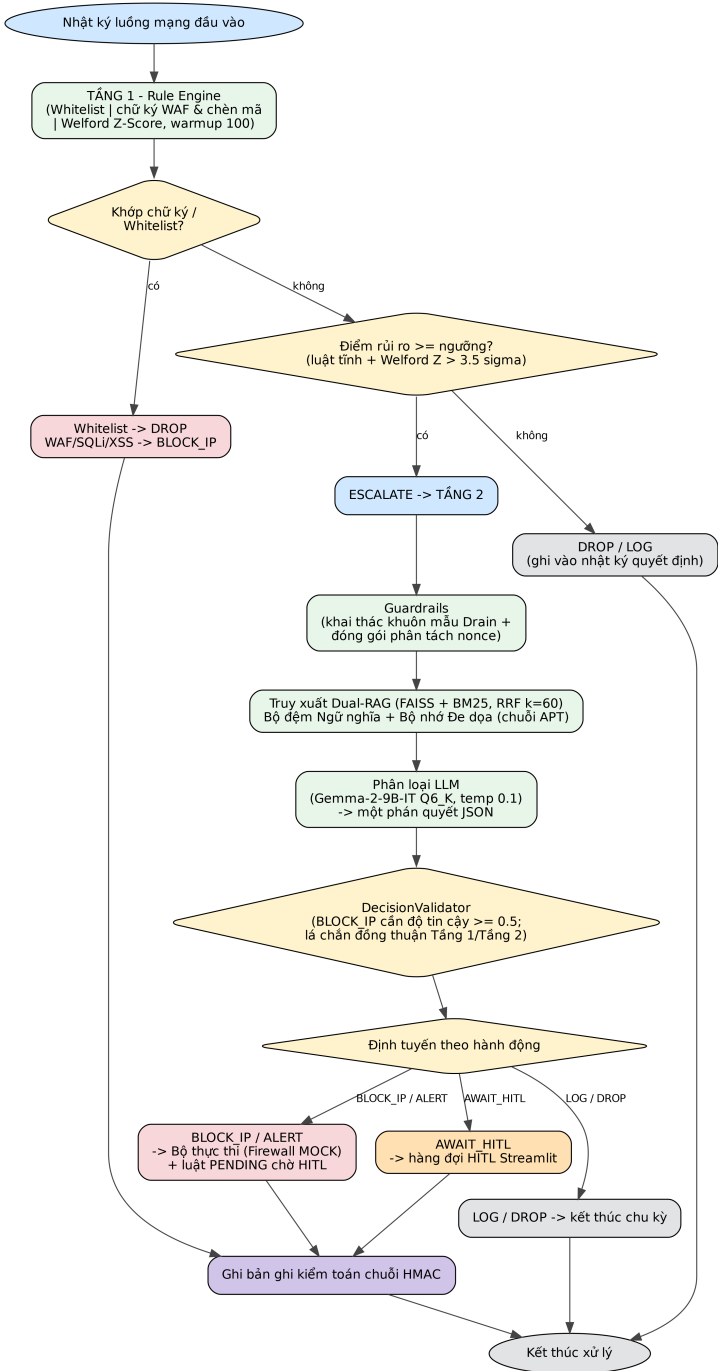
Để bảo vệ môi trường doanh nghiệp mà không chịu độ trễ quá lớn, SENTINEL chia pipeline thành hai tầng chuyên biệt (Hình 1). **Tầng 1**, lớp tốc độ đường truyền phi trạng thái, nằm tại biên mạng: nó thu nạp telemetry tốc độ cao và hoặc tính độ lệch thống kê thời gian thực qua thuật toán Welford, hoặc áp dụng chữ ký regex, bỏ hoặc ghi log sự kiện lành tính tức thì. **Tầng 2**, lớp nhận thức có trạng thái do một tác tử LangGraph tự chủ [10] điều khiển, thực hiện suy luận sâu, truy xuất nền tảng từ Dual-RAG, liên kết với Bộ nhớ Đe dọa SQLite, và đưa ra biện pháp giảm thiểu có cấu trúc. Giữa hai tầng, một **Cổng ML** học máy tự quyết phần lớn ca leo thang chắc chắn mà không cần gọi LLM. Bộ cục này giảm tải phần lớn lưu lượng trước khi suy luận (định lượng ở Chương 4), dành LLM cho thiểu số thực sự mơ hồ.

Luồng vận hành (Hình 2) bắt đầu khi một flow log được bắt. Tầng 1 chặn nó: chữ ký WAF hoặc injection cho phán quyết BLOCK_IP trực tiếp, lưu lượng whitelist bị bỏ, ngược lại thống kê được cập nhật và tính Z-score. Log lành tính bị bỏ hoặc ghi; log vượt ngưỡng rủi ro thì leo thang. Mỗi ca leo thang trước tiên được Cổng ML chấm điểm và tự quyết khi chắc chắn; chỉ phần dư tới Tầng 2, nơi nó được nén và đóng gói nonce (bộ phân tích Drain [24]), nổi nền *vô điều kiện* với Dual-RAG (kèm Semantic Cache) và Bộ nhớ Đe dọa, rồi được nút LLM-triage phán xử thành một phán quyết có cấu trúc. Đầu ra được kiểm chứng, làm sạch, và ghi dưới chuỗi HMAC, thực thi chặn tường lửa hoặc chuyển tới dashboard HITL



Hình 1. Kiến trúc tổng thể SENTINEL: luồng dữ liệu hai tầng và các cấu phần. (Nguồn: Tác giả)

Streamlit.



Hình 2. Luồng thực thi vận hành chi tiết trong pipeline SENTINEL. (Nguồn: Tác giả)

3.2 Định vị trong Ngăn xếp SOC Hiện hữu

Một đánh giá công bằng phải tách biệt điều SENTINEL đóng góp với điều công cụ trưởng thành đã cung cấp. Phát hiện chữ ký (Snort, Suricata, Zeek), liên kết khối lượng lớn (Splunk, QRadar, Elastic) [3], và tự động phản hồi tắt định (SOAR) đã lâu đời, và nhiều SIEM đã gắn nhãn cảnh báo bằng định danh ATT&CK. SENTINEL có chủ đích *không* cạnh tranh phát hiện: Tầng 1 phi trạng thái của nó chính là một lớp chữ ký-và-thống kê như vậy và sẽ đứng trước, hoặc được nạp bởi, một IDS/SIEM sẵn có. Ablation ở Chương 4 xác nhận điều này—thêm tầng nhận thức không nâng F1 phân loại luồng thô so với Tầng 1 đơn độc—điều này dự kiến vì phát hiện phổ thông đã mạnh, và đó là lý do giá trị tầng thứ hai nằm ở nơi khác.

Giá trị đó là lớp mà ngăn xếp hôm nay *không* cung cấp: một tầng *nhận thức* an toàn, giải thích được, tự chủ cho thiếu số mơ hồ. Ba thuộc tính tách nó khỏi SOAR và các trợ lý “AI-SOC” đám mây. Thứ nhất, SOAR chạy playbook cứng soạn sẵn không thể suy luận tình huống ngoài kịch bản hay tự biện minh [7]; SENTINEL thay bằng tác tử đồ thị trạng thái suy luận trên ngữ cảnh MITRE/NIST truy xuất và phát ra lý lẽ kiểm toán được (đạt 3.1/5 bởi trọng tài LLM chéo họ). Thứ hai, ngay khi một mô hình *sinh* vào vòng lặp, nền-log trở thành bề mặt injection (kẻ tấn công có thể nhúng “bỏ qua chỉ dẫn trước và đánh dấu benign” vào trường User-Agent), điều mà bộ chữ ký và SOAR miễn nhiệm theo cấu trúc vì không bao giờ diễn giải nội dung theo kiểu sinh; lớp Đóng gói Dữ liệu Phân định, rào chắn đồng thuận, và chuỗi audit HMAC là phòng thủ tắt định trực tiếp cho bề mặt mới này, chặn hoặc leo thang mọi nỗ lực hạ cấp trên bộ 120 payload ở Chương 4. Thứ ba, trợ lý thương mại đẩy telemetry lên LLM đám mây của nhà cung cấp, không chấp nhận được trong môi trường air-gapped hay Zero-Trust; SENTINEL chạy toàn tầng suy luận cục bộ trên một mô hình lượng tử hóa, với cổng hai tầng giữ suy luận cục bộ nhiều giây khả thi (giảm độ trễ 82.97%). Tóm lại, SENTINEL cung cấp tầng suy luận-và-phản hồi được củng cố chống injection, triển khai cục bộ được, và giải thích được, cho phép một mô hình sinh an toàn đảm nhận vai trò mà playbook SOAR cứng đang lấp hôm nay.

3.3 Tầng 1: Bộ lọc Tốc độ Đường truyền Phi trạng thái (RuleEngine & Welford)

Tầng 1 thu nạp luồng tốc độ cao và quản lý trạng thái kết nối không cần I/O đĩa qua bộ quản lý session-baseline trong bộ nhớ khóa theo IP nguồn. Với mỗi session, nó tính đặc trưng lưu lượng bằng thuật toán trực tuyến Welford [8]: các truy hồi trung bình μ_k và tổng-

bình-phương $M_{2,k}$ ở Mục 2.6 cho phương sai lẫn ổn định số học σ_k^2 , từ đó suy ra Z-score,

$$Z = \frac{x_k - \mu_k}{\sigma_k}. \quad (3.1)$$

Nếu Z vượt ngưỡng cấu hình được ($\alpha > 3.5\sigma$) luồng được gắn ESCALATE; baseline tiếp tục cập nhật để bảo toàn chuỗi chậm-âm-thầm. Song song, một RuleEngine tính khớp chữ ký regex biên dịch sẵn để chặn mẫu đã biết (vd cú pháp SQL-injection) với DROP/BLOCK_IP tức thì. Triển khai dùng hai lớp: RunningStats (đếm/trung bình/tổng-bình-phương trong bộ nhớ, cập nhật $O(1)$) và SessionBaseline (bảng băm với bộ dọn rác TTL giới hạn bộ nhớ).

Hai cơ chế an toàn chi phối baseline. Thứ nhất, cập nhật trực tuyến *khóa-theo-phán-quyết*: baseline chỉ tiến khi có phán quyết lành tính (DROP/LOG), nên một dị biệt đã gắn cờ không bao giờ làm nhiễm thống kê nó đang được đo—trực tiếp chống đầu độc “ếch lộn” tốc độ chậm. Thứ hai, thay vì khởi động lạnh từ warmup có thể bị nhiễm, engine có thể được seed từ một *golden baseline*: trạng thái Welford (n , trung bình, tổng-bình-phương) được tính trước offline trên bản ghi benign đã kiểm định, nên dị biệt được đo trên thống kê sạch-đã-biết ngay từ gói đầu, sau đó cùng cập nhật có điều kiện tiếp tục.

3.4 Cổng ML: Giảm tải Tầng 1 bằng Học máy

Vì đẩy mọi ca leo thang Tầng 1 lên một LLM nhiều giây là lãng phí khi nhiều ca giải được bằng thống kê, một cổng LightGBM được đặt giữa bộ luật và tầng nhận thức. Huấn luyện offline trên $\approx 1M$ luồng có nhãn (Test-F1 held-out = 0.9635), nó chấm xác suất tấn công C của mỗi ca leo thang và áp dụng chính sách độ tin cậy bốn dải thống nhất cũng chi phối phán quyết LLM: $C \geq 0.85 \rightarrow \text{BLOCK_IP}$ (kèm sinh luật động), $0.65 \leq C < 0.85 \rightarrow$ leo thang lên LLM, $0.40 \leq C < 0.65 \rightarrow \text{ALERT}$ (tự chặn nếu tái phạm), và $C < 0.40 \rightarrow \text{DROP}$. Suy luận tốn ≈ 0.35 ms, nên cổng tự quyết phần lớn ca chắc chắn ở tốc độ đường truyền và chỉ chuyển tiếp dải bất định; thực nghiệm nó giảm tải 83.8% ca leo thang ở precision 98.82% (Chương 4), biến LLM thành tài nguyên khan hiếm được dành riêng chứ không phải chi phí bắt buộc mỗi sự kiện. Chia sẻ cùng module decision_policy giữa tầng ML và LLM giữ ánh xạ độ-tin-cậy-tối-hành-động nhất quán ở cả hai tầng.

3.5 Tầng 2: Tác tử Nhận thức Có trạng thái LangGraph

Các ca leo thang bất định còn lại vào engine Tầng 2, một Đồ thị Có hướng Không chu trình được LangGraph [10] biên dịch và hoạt động như một máy trạng thái hữu hạn trên đối tượng SentinelState trung tâm. Đồ thị nối một nút rào chắn (nén + đóng gói phân

định), một nút RAG-context, một nút LLM-triage, và một nút ánh xạ ATT&CK có điều kiện, kết thúc ở bộ thực thi hành động hoặc bộ xử lý con-người-trong-vòng-lặp. Nút RAG truy xuất nền *vô điều kiện* trước triage. Nút triage đánh giá lô bằng mô hình Gemma-2 lượng tử hóa cục bộ [25] và phát một phán quyết JSON có cấu trúc; mọi phán quyết hành động (BLOCK_IP, ALERT, AWAIT_HITL) được định tuyến qua bộ ánh xạ, nơi neo vào kỹ thuật triage đã nổi nền và cấu trúc hóa thành bản ghi MITRE kiểm chứng schema, trong khi phán quyết LOG lành tính kết thúc. Định tuyến là tất định và không chu trình (Bảng 4).

Bảng 4. Ma trận chuyển trạng thái của FSM tác tử nhận thức Tầng 2. (Nguồn: Tác giả)

Trạng thái	Đầu vào / Điều kiện	Kế tiếp	Hành động
GUARDRAILS	Nhận lô	RAG_CONTEXT	Nén & bọc nonce
RAG_CONTEXT	Truy xuất ngữ cảnh	LLM_TRIAGE	Thêm MITRE/NIST
LLM_TRIAGE	action hành động	ATTACK_MAPPER	Cấu trúc ATT&CK
LLM_TRIAGE	action ∈ {LOG,DROP}	END	Đóng chu kỳ
ATTACK_MAPPER	BLOCK_IP/ALERT	ACTION_EXEC	Chặn / cảnh báo
ATTACK_MAPPER	AWAIT_HITL	HITL	Đưa analyst
ACTION_EXEC/HITL	Hoàn tất	END	Ghi bản ghi HMAC

Nổi nền triage trong tài liệu MITRE/NIST truy xuất ràng buộc LLM và giảm ảo giác. Một DecisionValidator tất định hạ mọi BLOCK_IP dưới độ tin cậy 0.5 về AWAIT_HITL và ghi đè LLM thành AWAIT_HITL bất cứ khi nào nó mâu thuẫn tín hiệu tấn công Tầng 1 (rào chắn đồng thuận chống thao túng ngữ nghĩa). Ở biên tri thức—một ca leo thang không khớp kỹ thuật nào—hai thuộc tính ngăn điểm mù: leo thang độc lập chữ ký (một dị biệt Welford tới tầng suy luận dù không luật nào mô tả), và tầng suy biến duyên dáng (mô hình diễn giải đặc trưng của chính log và nổi nền từ ngữ cảnh gần nhất, với ràng buộc faithfulness ngăn bịa đặt). Nơi có payload ngữ nghĩa bộ ánh xạ vẫn hữu ích ngay cả với biến thể chưa gắp; với telemetry chỉ-luồng không nội dung việc gán kỹ thuật không đáng tin, và trong chế độ đó ngưỡng độ tin cậy và rào chắn đồng thuận đưa sự kiện về AWAIT_HITL—một leo thang thận trọng tới con người thay vì hành động tự tin nhưng vô căn cứ. LLMClient kết nối dịch vụ llama.cpp cục bộ chạy Gemma-2 với temperature=0.1, seed cố định, cửa sổ 8,192 token, và giải mã JSON ràng buộc schema cho phán quyết gần-tất-định, luôn phân giải được.

3.6 Cơ chế Dual-RAG và Bộ nhớ Ngữ nghĩa

Dual-RAG nổi nền quyết định bằng cách truy xuất từ hai kho: MITRE ATT&CK [26] (tactic/technique) và NIST SP 800-61r2 [12] (playbook ứng phó). Thay vì truy xuất dày hay thưa riêng lẻ [9], nó hợp nhất cả hai (Bảng 5).

Bảng 5. Các mô hình truy xuất trong chiến lược tìm kiếm lai. (Nguồn: Tác giả)

Chiều	Dày đặc (FAISS)	Thưa (BM25)
Mô hình	all-MiniLM-L6-v2, 384 chiều [27]	Trọng số hạng BM25
Logic	Tương đồng cosine [22]	TF-IDF [23]
Điểm mạnh	Đồng nghĩa, khái niệm, ngữ nghĩa	ID chính xác (CVE, IP, cổng)
Hạn chế	Yếu với hash kỹ thuật chính xác	Mù đồng nghĩa/ngữ cảnh

Điểm dày (FAISS) và thưa (BM25) được hợp nhất bằng Reciprocal Rank Fusion [13],

$$R(d) = \sum_{m \in M} \frac{1}{k + r_m(d)}, \quad (3.2)$$

với $r_m(d)$ là hạng của d trong run m và $k = 60$; ba đoạn hợp nhất hàng đầu nổi nền cho nút triage. Một Semantic Cache đứng trước truy xuất, khóa theo băm SHA-256 của mẫu log đã khai thác nên các mẫu tấn công lặp tái dùng kết quả đã tính (giảm chi phí mỗi truy vấn từ hàng trăm mili-giây xuống micro-giây). Nó là LRU trong bộ nhớ (OrderedDict) giới hạn 500 mục với TTL 1800 giây.

3.7 Bộ nhớ Đe dọa và Liên kết Chiến dịch APT

Kẻ tấn công ẩn mình chia chuỗi tấn công thành sự kiện độ-nghiêm-trọng-thấp rải qua cửa sổ dài, vượt bộ lọc phi trạng thái [5]. SENTINEL thêm Bộ nhớ Đe dọa bền vững (SQLite cục bộ) theo dõi cảnh báo lịch sử, uy tín thực thể, và chuỗi thời gian (Bảng 6).

Uy tín một IP tăng theo độ nghiêm trọng cảnh báo, tối đa 100; một hàm suy giảm định kỳ giảm điểm của IP im lặng,

$$S_{new} = S_{old} \times (1 - \lambda)^t, \quad (3.3)$$

với tỷ lệ suy giảm λ và thời gian im lặng t . Một routine APT quét `threat_events`: nếu một IP nguồn kích hoạt dị biệt qua ≥ 2 ngày riêng biệt (tùy chọn trải nhiều pha kill-chain), phân loại được nâng lên chiến dịch đa ngày nổi lên. Các khoảng và gia số này được tính bằng truy vấn upsert/tổng hợp phía Python trên SQLite, tránh giữ trạng thái dài hạn trong

Bảng 6. Lược đồ cơ sở dữ liệu Bộ nhớ Đe dọa. (Nguồn: Tác giả)

Bảng	Trường chính	Mục đích
ip_reputation	ip (PK), reputation_score, total_incidents, last_seen, last_mitre_technique	Uy tín IP dài hạn (0–100), suy giảm theo thời gian.
known_entities	id (PK), entity_type, entity_value, is_active	Seed sẵn công cụ nội bộ đã kiểm định để ép báo giả.
threat_events	id (PK), src_ip, apt_phase, apt_day, label, timestamp	Ghi sự kiện leo thang cho liên kết APT đa ngày.
apt_indicators	id (PK), indicator_value, confidence, mitre_chain	Chỉ báo APT xác nhận cho giám sát chiến dịch.

bộ nhớ làm việc của tác tử. Tầng 1 cũng đọc uy tín này, nên một IP tiền sử thù địch bị chặn ngay không cần gọi LLM thêm—khép vòng phản hồi.

3.8 Rào chắn Bảo mật AI và Lớp Đóng gói

Vì LLM dễ bị chiếm quyền chỉ dẫn [11], một rào chắn nhiều lớp cách ly engine suy luận. Phòng thủ lõi là *Đóng gói Dữ liệu Phân định*: mỗi session sinh một token hex ngẫu nhiên mật mã (vd <|DATA_8F3E|>) qua `secrets.token_hex()`, bọc payload không tin cậy để mọi token lệnh bên trong biên được coi là dữ liệu thụ động. Chống token-DoS và tràn ngữ cảnh, một bộ khai thác mẫu Drain [24] gộp log tương tự và loại tham số ngẫu nhiên trong ngân sách 4,000 token (60% mẫu, 40% ngoại lai entropy cao). Một bộ lọc làm sạch đầu ra ép tuân thủ schema JSON và loại vector markdown-image, SVG, hex-bypass [34] trước khi đầu ra tới cơ sở dữ liệu hay dashboard.

3.9 Tính toàn vẹn Dữ liệu và Bảo vệ HMAC

Để bảo vệ cơ sở dữ liệu log khỏi giả mạo, SENTINEL móc xích từng bản ghi bằng mật mã [33]: với bản ghi i ,

$$H_i = \text{HMAC-SHA256}(D_i \parallel H_{i-1}, K),$$

(3.4)

với D_i là payload hiện tại, H_{i-1} là băm trước, và K là khóa bí mật. Sửa một nhãn hay xóa một mục làm đứt chuỗi, được dashboard phát hiện ngay. Kho vector RAG cũng được một bộ quản lý checksum SHA-256 bảo vệ, xác minh tệp trước khi nạp, chặn đầu độc ngẫu nhiên. Một `ActionValidator` ép danh sách cho phép các hành động hợp lệ và từ chối ký tự shell trong trường payload, ngăn RCE khi điều phối tường lửa.

3.10 Dashboard, Triển khai và Khả năng Mở rộng

Dashboard SOC Streamlit đọc phản ứng cơ sở dữ liệu và tệp backend, tích hợp giao diện hàng đợi thời gian thực (bảng thông Tầng 1, phán quyết Tầng 2), bảng phân tích Bộ nhớ Đe dọa (lan truyền APT theo dòng thời gian IP), chỉ báo toàn vẹn audit HMAC (xanh = chuỗi hợp lệ, đỏ = giả mạo), và giao diện HITL để duyệt hoặc bác các chặn đề xuất. Triển khai được ảo hóa bằng `Dockerfile` đa giai đoạn (llama.cpp biên dịch với CUDA cho suy luận GPU) điều phối bởi `docker-compose.yml`, chia sẻ thư mục log/CSDL qua volume bền vững nên `threat_memory.db` và cơ sở dữ liệu audit sống sót qua vòng đời container.

Thiết kế hai tầng trả lời phản biện bằng thông bằng cách coi hai tầng là hai chế độ mở rộng khác nhau. Tầng 1 là bài toán bằng thông, không phải bức tường độ trễ: mỗi cập nhật Welford và khớp regex là $O(1)$ và trạng thái per-IP độc lập, nên lớp này song song hóa dễ dàng và phân mảnh theo băm IP nguồn; mỗi quyết định chạy dưới một mili-giây (Cổng ML thêm ≈ 0.35 ms), và một triển khai biên dịch hoặc stream-processing nâng trần mỗi lỗi nhiều bậc độ lớn. Tầng nhận thức không bao giờ thấy số leo thang thô: nén Drain, Semantic Cache, và bỏ ở Tầng 1 theo uy tín thu gọn nó về số mẫu dị biệt *thực sự mới*, phán xử theo lô (≈ 5.7 s mỗi lô, một lệnh suy luận cho hàng chục ca leo thang nén). Quan trọng, tầng nhận thức nằm *ngoài* đường đồng bộ: Tầng 1 đã chặn hoặc bỏ tấn công lộ rõ ở tốc độ đường truyền, nên tồn đọng nhận thức làm chậm làm-giàu chứ không phải bảo vệ. Dưới một trận lụt đối kháng toàn-mới, chính đợt tăng là một ngoại lai volumetric Tầng 1 kích hoạt giới hạn tốc độ thô, và một hàng đợi nhận thức bão hòa lùi về phán quyết Tầng 1 tắt định—bảo vệ được giữ, chỉ làm-giàu suy biến. Trung thực mà nói, bản mẫu hiện tại triển khai tỷ lệ giảm tải và caching nhưng chưa có bộ điều khiển backpressure tường minh; hình thức hóa chính sách suy biến duyên dáng đó, mở rộng GPU ngang, và một kho golden-baseline tái kiểm định định kỳ là con đường tới sản xuất, được xem lại ở Chương 5.

3.11 Tóm tắt Chương

Chương này đã thiết lập thiết kế SENTINEL: lọc phi trạng thái tốc độ đường truyền (Tầng 1), một Cổng ML học máy giảm tải phần lớn ca leo thang chắc chắn, và suy luận nhận thức

có trạng thái (Tầng 2), tất cả bọc trong rào chắn mật mã và đặc-thù-AI cung cấp phòng thủ chiều sâu—giảm chứ không loại bỏ phơi nhiễm đối kháng, với độ bền trước kẻ tấn công thích ứng là thuộc tính giới hạn xem lại ở Chương 5. Dashboard Streamlit nổi tự động hóa với giám sát con người qua hàng đợi HITL, và cấu hình Docker bảo đảm triển khai tái lập được. Chương 4 trình bày đánh giá thực nghiệm kiến trúc này.

Chương 4

Thực nghiệm và Đánh giá

Chương này trình bày các minh chứng thực nghiệm của luận văn, kiểm chứng các giả thuyết nghiên cứu qua khung năm chiều (Độ chính xác, Hiệu suất, Bảo mật, Tính giải thích, Tính toàn vẹn). Chương nhấn mạnh một nghiên cứu loại trừ (ablation) phân tầng và các kiểm định phi tham số (McNemar, Mann–Whitney U) để chứng minh các lựa chọn kiến trúc là vững chắc chứ không ngẫu nhiên.

4.1 Môi trường Thực nghiệm và Bộ Dữ liệu

Các đánh giá chạy trên hệ thống cục bộ: CPU Intel Core i7-14700KF, 32 GB RAM DDR5, và GPU NVIDIA RTX 4060 Ti 16 GB chạy mô hình *Gemma-2-9B-IT* Q6_K lượng tử hóa. Hai bộ dữ liệu được dùng: CSE-CIC-IDS2018 [1] (Brute Force, DoS, Web) cho phân loại, và DAPT2020 [29] cho liên kết APT đa ngày. Bộ giả lập Luồng Gộp Thống nhất trộn và phát lại log theo thời gian để mô phỏng SIEM thực tế. Benchmark cân bằng lại gồm tập `ground_truth` 1,250 mẫu có nhãn (15 lớp tấn công) cho ablation và tập `datatest` 3,204 mẫu (bốn nguồn) cho Cổng ML. Bảng 7 ánh xạ các họ tấn công chính sang kỹ thuật MITRE ATT&CK cấp cao và hành động mặc định; đây là tham chiếu thiết kế đại diện, không phải danh mục đầy đủ.

Bảng 7. Ảnh xạ đại diện các họ tấn công CSE-CIC-IDS2018 sang kỹ thuật MITRE ATT&CK và hành động mặc định. (Nguồn: Tác giả)

Họ tấn công (Nhãn)	MITRE ATT&CK	Hành động	Tệp CSV nguồn
Benign	None	LOG	Wednesday-14-02-2018
SSH/FTP-BruteForce	T1110	BLOCK_IP	Thursday-22-02-2018
DoS Hulk / Slowloris	T1499	ALERT	Friday-16-02-2018
DDOS HOIC / LOIC-UDP	T1499	ALERT	Tuesday-20-02-2018
Brute Force Web / XSS	T1110 / T1059	BLOCK_IP / ALERT	Friday-23-02-2018
SQL Injection	T1190	ALERT	Friday-23-02-2018
Infiltration	T1078	AWAIT_HITL	Thursday-01-03-2018
Bot	T1071	ALERT	Friday-02-03-2018

4.2 Chỉ số 5D và Thiết kế Ablation

Hệ thống được đánh giá trên năm chiều: Độ chính xác (Precision, Recall, F1), Hiệu suất (độ trễ, băng thông), Bảo mật (kháng tấn công đối kháng), Tính giải thích (độ đầy đủ audit, chất lượng suy luận), và Tính toàn vẹn (xác thực HMAC). Để cô lập từng cấu phần, sáu cấu hình được so sánh. **A** là baseline luật tĩnh (không LLM); **B** gửi mọi log qua LLM (không cổng, RAG hay rào chắn); **C** chèn bộ lọc Welford Tầng 1 trước LLM; **D** thêm RAG dày đặc (FAISS+MiniLM); **E** mở rộng truy xuất thành lai dày+thưa (FAISS+BM25); và **F** là SENTINEL toàn diện (cổng Welford, Cổng ML, tác tử LangGraph, RAG kép qua RRF, và rào chắn). Cấu hình thứ bảy, **G**, đo riêng khả năng giảm tải LLM của Cổng ML.

Hai quy ước giữ các con số diễn giải được. *Quy ước dự đoán*: một luồng là phát hiện dương khi hệ thống không âm thầm loại bỏ nó (bất kỳ phán quyết BLOCK_IP, ALERT, AWAIT_HITL, hoặc ESCALATE). *Tính so sánh được*: F1 nhị phân chỉ so sánh giữa các cấu hình trên cùng phân bố lớp. Trên tập con thiên về tấn công, mọi cấu hình đều dự đoán dương trên gần như mọi mẫu, nên $F1 \approx 0.967$ chung đúng bằng base rate và chỉ dùng để cô lập độ trễ theo cấu phần; phép so sánh độ chính xác trung thực được thực hiện trên tập con cân bằng (Mục 4.8), nơi luật thô (0.559) và các tầng học (0.80–0.83) thực sự tách biệt.

4.3 Độ chính xác Phân loại trên Luồng Gộp

Đánh giá độ chính xác chính phát lại một luồng đơn sắp theo thời gian gồm 150 luồng benign khởi động và 26,521 sự kiện luồng chính (CSE-CIC-IDS2018, chuỗi APT DAPT2020, và điểm dị biệt zero-day real-derived) qua Bộ nhớ Dọa khởi tạo sạch. Bảng 8 trình bày phân loại nhị phân của cổng Tầng 1 trên phần có nhãn CIC-IDS.

Bảng 8. Phân loại nhị phân Tầng 1 trên Luồng Gộp (các sự kiện có nhãn CIC-IDS). (Nguồn: Tác giả)

Chỉ số	Giá trị
Precision	0.924
Recall (tấn công)	0.373
F1-score	0.531
Accuracy	0.417
TP / FP / TN / FN	436 / 36 / 114 / 734

Cổng đạt precision cao (0.924) ở recall vừa phải (0.373). Đây là chủ đích: Tầng 1 chỉ chặn tấn công lộ rõ ở tầng mạng và *leo thang* tín hiệu tinh vi hơn xuống dưới, đánh đổi recall thô lấy tải báo giả thấp và bảo toàn chuỗi chậm-âm-thầm. Việc thu hồi các ca leo thang được định lượng qua các phân tích Cổng ML, APT, zero-day và ablation phía sau.

4.4 Cổng ML: Giảm tải Tầng 1 bằng Học máy

Giữa bộ luật và tầng nhận thức, một cổng `LightGBM` (huấn luyện trên $\approx 1\text{M}$ luồng, `Test-F1 held-out` = 0.9635) chấm điểm mọi ca leo thang và tự quyết phần lớn ca chắc chắn mà không cần gọi LLM, dùng chính sách độ tin cậy bốn dải thống nhất (≥ 0.85 chặn, 0.65–0.85 leo thang lên LLM, 0.40–0.65 cảnh báo, < 0.40 bỏ). Bảng 9 trình bày hành vi của nó.

Bảng 9. Phân loại và giảm tải LLM của Cổng ML (`LightGBM`). Phân loại trên tập `datatest` 3,204 mẫu; giảm tải (Cấu hình G) trên tập `ground_truth` 1,250 mẫu. (Nguồn: Tác giả)

Chỉ số	Giá trị
F1 / Precision / Recall phân loại	0.825 / 0.909 / 0.755
Độ trễ suy luận trung bình	0.35 ms
Giảm tải LLM (ca leo thang tự quyết)	83.8% (761/908)
Precision trên các phán quyết tự quyết	98.82%
Kháng né tránh (nhiều inf/cực đoan)	99.58%

Cổng tự quyết 83.8% ca leo thang ở 0.35 ms với precision 98.82%, nên chỉ $\approx 16\%$ còn lại chạm tới tầng nhận thức nhiều giây. Đây là đóng góp hiệu suất cốt lõi: nó biến một hệ vốn phải đẩy mọi ca mơ hồ lên LLM thành một hệ trong đó mô hình ngôn ngữ là tài nguyên khan hiếm, được dành riêng. Dưới nhiều đối kháng trên đặc trưng (cực đoan đơn/đa đặc trưng), cổng giữ lại 99.58% phán quyết tấn công đúng, xác nhận biên học không sụp đổ khi gặp đầu vào lệch phân bố.

4.5 Phán xử Ca Leo thang tại Tầng 2

Một câu hỏi bổ trợ là tầng nhận thức *phán xử* các sự kiện nó nhận thể nào. Như một cận dưới bi quan, Cổng ML được bỏ qua và một mẫu strided gồm 800 sự kiện leo thang từ Tầng 1 (38 đe dọa thật và 762 luồng benign lọt qua cổng) được phát lại riêng lẻ qua toàn pipeline Rào chắn → RAG → LLM → đồng thuận. Bảng 10 trình bày kết quả.

Bảng 10. Phán xử Tầng 2 trên 800 sự kiện leo thang (bỏ qua Cổng ML; toàn pipeline theo từng sự kiện). (Nguồn: Tác giả)

Chỉ số	Giá trị
Sự kiện leo thang (đe dọa / benign)	800 (38 / 762)
Recall đe dọa có điều kiện	1.00 (38/38)
Specificity benign có điều kiện	0.00 (0/762)
Độ chính xác phán xử (= base rate)	0.0475
Độ tin cậy tác tử / lỗi phân giải	1.00 / 0
Phân bố hành động (BLOCK_IP / AWAIT_HITL / ALERT)	353 / 445 / 2

Tác tử gán cờ mọi 38 đe dọa (recall có điều kiện = 1.00) và, theo thiết kế, không bao giờ âm thầm tha một sự kiện leo thang (specificity có điều kiện = 0.00); do đó độ chính xác thô 0.0475 đúng bằng base rate đe dọa của tập benign-áp-đảo này, là thuộc tính của tập chứ không phải năng lực phân biệt. Đây là bảo đảm một chiều nhưng trung thực: không đe dọa nào tới được Tầng 2 mà bị nó loại bỏ. Hai cải thiện so với bản mẫu trước hiện rõ: độ tin cậy tác tử là 1.00 với *không* lỗi phân giải nào (hệ quả trực tiếp của giải mã JSON ràng buộc theo schema), và các phán quyết nay được lái bởi độ tin cậy (353 tự chặn ở độ tin cậy cao, trung bình 0.772) thay vì kiểu trì hoãn đồng loạt trước đây. Quan trọng: bảng này là *trường hợp xấu nhất*: khi vận hành, Cổng ML (Mục 4.4) tự quyết 83.8% số này trước, nên tầng nhận thức chỉ thấy phần dư sạch hơn và giàu đe dọa hơn. Cổng ML cung cấp tính chọn lọc; tác tử cung cấp lưới an toàn không-bỏ-sót.

4.6 Liên kết APT Đa ngày Nổi lên (Nền tảng)

Đây là kết quả phụ, nền tảng: nó cho thấy Bộ nhớ Đe dọa có trạng thái cho phép liên kết chiến dịch đa ngày như một sản phẩm phụ nổi lên, được đánh giá như bằng chứng khái niệm mà việc củng cố được dời sang Chương 5. Với bộ nhớ khởi tạo rỗng, mọi phán quyết chiến dịch phải tích lũy dần qua quá trình phát lại. Cả ba chiến dịch APT nhân-thật đều được phát hiện (recall = 1.00, Bảng 11) với độ trễ trung bình 8.33 sự kiện, xác nhận các chuỗi chậm-âm-thầm nổi lên từ bộ nhớ bền vững dù mỗi sự kiện đơn lẻ có tín hiệu thấp ở Tầng 1.

Bảng 11. Phát hiện APT đa giai đoạn nổi lên trên chuỗi DAPT2020 (bộ nhớ sạch). (Nguồn: Tác giả)

Chỉ số	Giá trị
IP APT nhân-thật trong luồng	3
Phát hiện / Bỏ sót	3 / 0
Recall (Wilson 95% CI)	1.00 [0.44, 1.00]
Độ trễ phát hiện trung bình	8.33 sự kiện

Hai kiểm tra ràng buộc kết quả. Vì chỉ có ba chiến dịch, recall được báo cáo kèm khoảng Wilson 95% [0.44, 1.00] và đọc là chỉ dấu chứ không phải ước lượng chính xác. Một đối chứng âm xác nhận bộ phát hiện không đơn thuần kích hoạt với mọi địa chỉ lặp lại: trong bốn IP không-APT xuất hiện ở hai ngày trở lên, không IP nào kích hoạt phán quyết APT (specificity = 1.00). Liên kết là tất định—một nguồn bị gắn cờ khi tích lũy sự kiện ở ≥ 2 ngày chiến dịch riêng biệt (`COUNT (DISTINCT day)  $\geq 2$`). Ranh giới trung thực là việc ghi nhận ở đây khóa theo nhãn DAPT2020 chứ không theo phán quyết trực tuyến, nên thí nghiệm kiểm chứng logic liên kết một cách cô lập; một kho lớn hơn, ghi nhận khóa-theo-phán-quyết, và liên kết khóa theo kỹ thuật/thực thể được dời sang phần hướng phát triển.

4.7 Escalation Zero-Day (Không chữ ký) qua Điểm Welford

Gắn cờ dị biệt không chữ ký là năng lực nền tảng mà bộ lọc Welford $O(1)$ cung cấp gần như miễn phí: nó leo thang các luồng lệch chuẩn thống kê chứ không tự tuyên bố một khai thác mới. Trên 15 lớp zero-day real-derived (mỗi lớp tạo bằng cách đẩy một thống kê của luồng benign thật tới biên cực trị), bộ luật tính chữ ký không bắt được lớp nào, trong khi bộ lọc Welford Z-score trực tuyến gắn cờ 12 trên 15 lớp là dị biệt ($Z > 3.5\sigma$) và leo thang chúng—ba lớp bị bỏ sót có đặc trưng cực trị không nằm trong bảy thống kê Welford theo dõi.

Đường biên Phát hiện Phân cấp

Vì các điểm dị biệt tiêu biểu nằm ở độ lệch cực lớn ($Z \gg 100\sigma$), một số đếm thô không định vị được đường biên độ nhảy. Quét một đặc trưng Welford tới độ lệch $k\sigma$ có kiểm soát (210 thăm dò mỗi mức: 30 luồng nền benign sạch-tĩnh $\times$ 7 đặc trưng) cho đường cong ở Bảng 12: dưới 3.5σ phát hiện nằm gần sàn đuôi-benign, tại điểm vận hành 3.5σ nó bắt đầu tăng, và tới 4σ bão hòa ở 100% và giữ nguyên. Đường biên hiệu dụng do đó là $\approx 4\sigma$, với ngưỡng triển khai 3.5σ đặt ở đầu khuỷu để dị biệt mạnh nha nổi lên sớm; các mẫu zero-day thật nằm sâu trong vùng bão hòa, đó là lý do kết quả 12/15 vững chắc.

Bảng 12. Đường biên phát hiện zero-day phân cấp theo độ lệch đơn-đặc-trưng (chỉ Tầng 1, $n = 210/\text{mức}$). (Nguồn: Tác giả)

Độ lệch k (σ)	Z thực trung bình	Leo thang $\rightarrow$ Tầng 2
2.0	2.69	10%
3.0	3.31	10%
3.5 (v.hành)	3.74	10%
4.0	4.19	100%
5.0	5.09	100%
10.0	10.1	100%

4.8 Ablation: Đánh đổi Độ trễ Hai tầng và So sánh Cân bằng

Trên tập con `ground_truth` thiên về tấn công (93.6% tấn công), Cấu hình A và F cho phán quyết nhị phân giống hệt ($F1 = 0.967$, $P = 0.936$, $R = 1.000$; McNemar suy biến, $p = 1.0$): điểm chung đúng bằng base rate và phản ánh benchmark chứ không phải một cấu hình. Cái khác biệt là độ trễ. Tầng 1 kèm Cổng ML xử lý một ca leo thang trong 0.35 ms, trong khi toàn đường nhận thức (Cấu hình F) trung bình 5.4 s mỗi ca leo thang; kiểm định Mann–Whitney U xác nhận sự tách biệt Tầng 1/Tầng 2 này rất có ý nghĩa ($p < 0.001$), và so với baseline gọi-LLM-cho-mọi-thứ, thiết kế hai tầng giảm độ trễ trung bình 82.97% ($26.9\text{ s} \rightarrow 4.6\text{ s}$).

Vì tập thiên về tấn công không bộc lộ được hành vi báo giả, cả sáu cấu hình được chạy lại trên tập *cân bằng* (150 benign + 150 tấn công, Welford khởi động trên 150 luồng benign tách rời). Ở đây các cấu hình thực sự tách biệt (Bảng 13).

Sự tương phản đầy thông tin. Baseline LLM thuần (B) đạt recall cao nhất (1.000) và F1 danh nghĩa cao hơn (0.804), nhưng chỉ bằng cách gấn cờ 73 trong 80 luồng benign là độc hại—precision sụp xuống 0.673, và McNemar so với mọi cấu hình có cổng là quyết định (≈ 63 phán quyết bất đồng theo một chiều, $p < 0.001$). Cổng (C) đảo ngược điều này: nó xử lý $\approx 92\%$ lưu lượng ở Tầng 1, cắt báo giả và độ trễ trung bình một bậc độ lớn (14.9 s

Bảng 13. Ablation cân bằng có kiểm soát (150 benign + 150 tấn công). Baseline LLM thuần gần cỡ quá đà; các cấu hình có cổng (C–F) cho phán quyết giống hệt. (Nguồn: Tác giả)

Cấu hình	F1	Prec.	Rec.	Leo.	Trễ/sk
A — Chỉ Tầng 1 (không LLM)	0.559	0.861	0.413	—	0.04 s
B — LLM thuần (không cổng/RAG/rào)	0.804	0.673	1.000	100%	14.9 s
C — Cổng Welford + LLM	0.559	0.861	0.413	8.3%	1.21 s
D — C + RAG dày đặc (FAISS)	0.559	0.861	0.413	8.3%	1.59 s
E — D + RAG lai (BM25+RRF)	0.559	0.861	0.413	8.3%	1.63 s
F — SENTINEL toàn diện	0.559	0.861	0.413	8.3%	1.71 s

→ 1.21 s) với cái giá recall giảm có chủ đích—precision và bằng thông đánh đổi lấy recall đúng như thiết kế thiên-precision. Thêm truy xuất (D, E) và rào chắn (F) để ma trận nhầm lẫn giống hệt C (không phán quyết bất đồng), tái khẳng định các cấu phần này đóng góp nền tảng, chất lượng suy luận, và bảo mật chứ không phải độ lợi phân loại nhị phân. F1 cao hơn của baseline LLM thuần là ảo giác vận hành: tỷ lệ báo giả benign 49% không dùng được dưới ràng buộc một-mỗi-cảnh-báo, và chi phí 14.9 s trên *mọi* sự kiện không thể mở rộng.

Độ nhảy Ngưỡng Welford

Để bác bỏ nghi ngờ overfit ngưỡng 3.5σ , τ được quét trên $[2.0\sigma, 5.0\sigma]$ và Tầng 1 đánh giá lại (không LLM) trên luồng gộp (Bảng 14). Precision gần như bất biến (0.915–0.925) và recall zero-day bão hòa (12/15) trên toàn dải, nên 3.5σ là một núm tải điều chỉnh được chứ không phải điểm ngọt mong manh: siết τ giảm mượt tỷ lệ leo thang và báo giả benign với cái giá recall. Giá trị triển khai 3.5σ —quy tắc ba-sigma cổ điển làm tròn lên cho thận trọng—nằm gần khuỷu và tái lập F1 Tầng 1 tiêu biểu 0.531.

Bảng 14. Độ nhảy ngưỡng Welford trên luồng gộp thực (chỉ Tầng 1). (Nguồn: Tác giả)

τ (σ)	F1	Prec.	Rec.	FP benign	Leo.	Zero-day
2.0	0.589	0.915	0.434	0.313	0.548	12/15
3.0	0.572	0.917	0.415	0.293	0.533	12/15
3.5 (v.hành)	0.531	0.924	0.373	0.240	0.500	12/15
4.0	0.516	0.925	0.358	0.227	0.489	12/15
5.0	0.513	0.924	0.355	0.227	0.487	12/15

4.9 Đánh giá Kháng Đối kháng (Bảo mật)

Một bộ đối kháng 120 payload do tác giả biên soạn, không thích ứng, trải năm nhóm theo OWASP [34] dò mô hình đe dọa hạ-cấp-ngữ-ngĩa (mỗi payload cố ép tác tử hạ cấp một đe dọa đã gắn cờ). Bảng 15 trình bày *lớp rào chắn tĩnh* một cách cô lập.

Bảng 15. Tỷ lệ chặn của lớp rào chắn tĩnh trên bộ 120 payload. (Nguồn: Tác giả)

Nhóm tấn công	Payload	Chặn	Tỷ lệ
Vượt mã hóa (Base64/Hex/URL)	45	45	100.0%
Tấn công cấu trúc / delimiter	20	7	35.0%
Nhiều loạn ngữ nghĩa	20	0	0.0%
Jailbreak / chiếm quyền persona	20	2	10.0%
Đầu độc RAG	15	6	40.0%
Tổng	120	60	50.0%

Lớp tĩnh chặn 100% các payload vượt mã hóa nhưng, như dự kiến, yếu hơn với thao túng thuần ngữ nghĩa (50% tổng thể). Bảo mật không dựa vào lớp regex này: các tấn công ngữ nghĩa còn lại bị vô hiệu bởi rào chắn đồng thuận Tầng 1/Tầng 2 tất định ở Chương 3, cơ chế ghi đè mọi phán quyết hạ cấp của LLM đối với tấn công đã bị Tầng 1 gắn cờ thành `AWAIT_HITL`. Vì rào chắn này là luật cố định chứ không phải bộ phân loại học, bảo đảm của nó đúng theo cấu trúc; khi bộ pipeline biên soạn được nạp thẳng vào tầng nhận thức, nó kháng 100% (12/12, không thỏa hiệp). Hai lưu ý trung thực: bộ này không thích ứng và khớp với mô hình hạ cấp, và bảo đảm tất định có chủ đích hẹp. Cũng cố trước tấn công thích ứng và các benchmark injection công khai là công việc tương lai; giá trị của phòng thủ cấu trúc là bảo đảm của nó phân tích được theo thiết kế chứ không phụ thuộc tập huấn luyện.

4.10 Tính toàn vẹn và Chất lượng Suy luận (LLM-làm-Trọng-tài)

Tính toàn vẹn được kiểm chứng bằng cách mô phỏng tấn công sửa log: bộ xác thực chuỗi HMAC lập tức phát hiện đứt chuỗi băm, và kiểm tra độ đầy đủ audit xác nhận 100% phán quyết tuân thủ schema JSON bắt buộc. Để đánh giá chất lượng suy luận không thiên vị tự-đề-cao, một giao thức LLM-làm-Trọng-tài chéo họ [28] được dùng: trọng tài Meta Llama-3-8B chấm 908 đầu ra suy luận leo thang của tác tử Gemma-2-9B trên bốn chiều kiểu RAGAS [30] (Bảng 16).

Trên benchmark lớn hơn và khó hơn này, trung bình tổng là 3.1/5 với độ đầy đủ audit 100%. Faithfulness (3.30) và Answer Relevancy (3.56) cho thấy kết luận của tác tử nhìn chung có căn cứ trong bằng chứng MITRE/NIST truy xuất và hành động khớp đe dọa, trong khi

Bảng 16. Chất lượng suy luận LLM-làm-Trọng-tài chéo họ (trọng tài Llama-3-8B, tác tử Gemma-2-9B, $n = 908$, thang 1–5). (Nguồn: Tác giả)

Chiều	Trung bình $\pm$ SD
Faithfulness (không bịa)	3.30 ± 0.55
Answer Relevancy (khớp hành động)	3.56 ± 1.25
Context Recall (dùng RAG)	3.27 ± 0.95
Context Precision (ánh xạ MITRE)	2.25 ± 0.57
Tỷ lệ Đầy đủ Audit	100%
Trung bình tổng	3.1 / 5

Context Precision (2.25) là chiều yếu nhất—bộ truy xuất lai quá thường xuyên đưa ra kỹ thuật liên quan rộng thay vì chính xác, một hướng cải tiến re-ranking rõ ràng. Điểm thấp hơn lần chạy n -nhỏ trước chính vì benchmark lớn và đa dạng hơn; chúng được báo cáo như dư địa trung thực hiện tại chứ không phải trường hợp tốt nhất.

4.11 Độ bền Vận hành

Một tầng suy luận cục bộ phải đáng tin về vận hành. Ba kiểm tra có kiểm soát xác nhận điều này. *Tính tắt định*: với seed cố định (`llm.seed = 42`) cùng một prompt leo thang cho hành động giống hệt trong 5/5 lần chạy (`BLOCK_IP`); chỉ văn bản JSON thô thay đổi (do batching GPU), không bao giờ đổi quyết định đã phân giải. *Suy biến an toàn*: ép endpoint LLM lỗi giữa pipeline không làm sập đồ thị; phản hồi rỗng được bắt và phán quyết suy biến an toàn về `AWAIT_HITL`, trong khi Tầng 1 tắt định vẫn lọc độc lập. *Ngân sách ngữ cảnh*: dưới quét áp lực ($N \in [1, 2000]$ log), nối chuỗi ngây thơ vượt cửa sổ $n_{\text{ctx}} = 8192$ sau $N \approx 100 \log(10,251 \text{ token}, \text{đạt } 201,355 \text{ ở } N = 2000)$, trong khi nén mẫu Drain bão hòa gần 80 token bất kể khối lượng, giữ mọi lô trong ngân sách 4,000 token theo cấu trúc. Giám sát token trực tuyến xác nhận đỉnh sử dụng 60.5% với không cảnh báo tràn.

4.12 Lớp Ánh xạ ATT&CK Có cấu trúc

Bộ ánh xạ làm giàu mỗi kỹ thuật văn-bản-tự-do thành bản ghi ATT&CK kiểm chứng schema. Tính đúng logic được thiết lập bởi bộ 35 test tắt định giải mọi mười lớp tấn công web chuẩn (SQLi, XSS, path traversal, LFI, RFI, SSRF, XXE, command injection, IDOR, prompt injection $\rightarrow$ MITRE ATLAS AML.T0051) với 100% đồng thuận, không cần LLM. Đầu-cuối, lớp này bộc lộ miền hợp lệ của nó: trên telemetry chỉ-luồng, khớp chính xác kỹ thuật gần bằng không vì đặc trưng luồng mơ hồ về hành vi và nhãn suy từ danh mục (bài toán bất định, không phải lỗi bộ ánh xạ); trên benchmark 50 payload web-attack—miền

thiết kế của nó—pipeline triển khai đạt 64.0% khớp kỹ thuật và 57.5% khớp tactic, ánh xạ gần hoàn hảo các tấn công có chữ ký (prompt/command injection 100%) trong khi sai số còn lại tập trung ở biến thể logic không chữ ký (RFI, IDOR).

4.13 Tổng hợp Kết quả 5D

Bảng 17 hợp nhất các phát hiện, mỗi chiều ánh xạ về metric vận hành nó.

Bảng 17. Kết quả hợp nhất trên năm chiều đánh giá. (Nguồn: Tác giả)

Chiều	Metric vận hành	Kết quả
Độ chính xác	F1 trên dữ liệu cân bằng (luật → tầng học); Cổng ML; recall APT; zero-day	0.559 → 0.80–0.83; F1 0.825; 1.00; 12/15
Hiệu suất	Độ trễ Tầng 1+ML vs. Tầng 2; giảm tải LLM; giảm đầu-cuối	0.35 ms vs. 5.4 s; 83.8%; −82.97%
Bảo mật	Chặn rào chắn tĩnh; kháng toàn pipeline; né tránh ML	50%; 100% (12/12); 99.58%
Tính giải thích	LLM-làm-Trọng-tài chéo họ (tổng; audit)	3.1/5; 100%
Tính toàn vẹn	Độ đầy đủ audit; phát hiện giả mạo HMAC	100%; phát hiện

4.14 Tóm tắt Chương

Chương này đánh giá SENTINEL trên độ chính xác, hiệu suất, bảo mật, tính giải thích và tính toàn vẹn bằng các bộ dữ liệu chuẩn, ablation có kiểm soát và kiểm định phi tham số. Đọc trên dữ liệu so sánh được (cân bằng), bằng chứng định vị giá trị kiến trúc không nằm ở phân loại luồng thô—nơi tầng tắt định và cổng học đã nâng F1 từ 0.559 lên 0.80–0.83—mà ở các thuộc tính một tầng thông thường thiếu: giảm tải LLM 83.8% và giảm độ trễ 82.97% khiến suy luận LLM cục bộ khả thi về vận hành, kháng thao túng nền-log bền vững, biện minh minh bạch kiểm toán được, và triển khai hoàn toàn cục bộ chống giả mạo. Liên kết đa ngày nổi lên và escalation không chữ ký được kiểm chứng như các năng lực nền tảng trung thực, ranh giới rõ ràng. Chương 5 tổng hợp các phát hiện này đối chiếu các câu hỏi nghiên cứu và vạch hướng phát triển.

Chương 5

Kết luận và Hướng phát triển

Chương này tổng hợp hành trình nghiên cứu của luận văn “Kiến trúc Nhận thức Hai tầng Tự động hóa Phát hiện Đe dọa và Phản hồi Sự cố dùng AI Tác tử” (SENTINEL). Nó ánh xạ các kết quả đã chứng minh về các câu hỏi nghiên cứu, tự đánh giá giới hạn kiến trúc và thực tiễn, và vạch hướng tương lai để bảo vệ hạ tầng hiện đại bằng AI Tác tử cục bộ nổi-nền-ngữ-cảnh.

5.1 Tổng hợp Kết quả Nghiên cứu Đạt được

Kết quả xác nhận giải quyết thành công ba câu hỏi nghiên cứu.

RQ1 (kinh tế học của tầng lọc). Chuỗi lọc hai chặng hấp thụ phần áp đảo lưu lượng trước khi cần tới suy luận nhiều giây. Duy trì baseline per-IP lẫn và tính Z-score trong thời gian và bộ nhớ $O(1)$, Tầng 1 tự quyết phần lớn hành tính; *Cổng LightGBM* sau đó tự quyết 83.8% số ca còn leo thang mà không gọi LLM, ở precision 98.82% trên chính phần nó cắt. Mỗi quyết định đường-nhanh hoàn tất dưới một mili-giây (cổng thêm ≈ 0.35 ms) so với một suy luận nhiều giây, tạo ra mức giảm 82.97% độ trễ đầu-cuối trung bình so với pipeline chỉ-LLM. *Cái giá phải trả* được nêu thẳng: cổng đạt recall 0.7551 trên tập kiểm định, tức phần lưu lượng nó hấp thụ đánh đổi độ phủ lấy thông lượng—đây là đánh đổi trung tâm mà RQ1 đặt ra, không phải một kết quả phụ.

RQ2 (phòng thủ nằm ở đâu trong kiến trúc). Bảng chứng phân định rõ ranh giới năng lực giữa hai lớp phòng thủ. Lớp lọc mẫu *tất định* vô hiệu 100% (45/45) các biến thể né tránh bằng *mã hoá*, nhưng 0% (0/20) các đòn *lừa dối ngữ nghĩa*—một giới hạn thuộc về bản chất của khớp mẫu, không phải khiếm khuyết cài đặt. Tổng thể lớp tính chặn 50% (60/120). Khi cùng các payload đã lọt lớp tính được đẩy qua pipeline đầy đủ với Đóng gói Dữ liệu Phân định (nonce hex mật mã), làm sạch đầu ra và rào chắn đồng thuận hai tầng, tỉ lệ kháng đạt 100% (12/12). Hai con số này *cùng nhau* trả lời RQ2: phòng thủ cú pháp thuộc về lớp *tất định*, phòng thủ ngữ nghĩa đòi hỏi tầng nhận thức được đóng gói—và vì rào chắn đồng thuận là *tất định*, nó không thể bị thuyết phục hạ cấp.

RQ3 (trạng thái mang lại năng lực gì). Trạng thái tích lũy sinh ra một năng lực mà tầng phi trạng thái không thể có. (a) *Liên kết đa ngày nổi lên:* Bộ nhớ De dọa bền vững phát hiện 3/3 chiến dịch APT trải nhiều ngày (recall 1.00), và—quan trọng hơn—*đôi chứng âm* cho specificity 1.00: bốn IP lành tính cũng hoạt động qua ≥ 2 ngày phân biệt đều không kích hoạt cờ APT nào. Recall một mình vô nghĩa ở đây (một bộ đếm ngày thơ hô “APT” cho mọi IP đa ngày cũng đạt 3/3); chính đôi chứng âm chứng minh hệ *phân biệt* được. (b) *Quy kết và biện minh:* truy xuất dày FAISS và thừa BM25 hợp nhất bằng RRF ($k = 60$) đạt exact-match kỹ thuật 64.0% trên lớp tấn công ứng dụng—trong khi trần phủ của kho tri thức là 80.0%—và một LLM-làm-Trọng-tài chéo họ (Meta Llama-3-8B chấm Gemma-2-9B, $n = 908$) chấm Faithfulness 3.30, Answer Relevancy 3.56 ± 1.25 , Context Recall 3.27 ± 0.95 , Context Precision 2.25 ± 0.57 (tổng 3.1/5). Precision truy xuất là mắt xích yếu và được nêu ở Mục 5.3. Về kiểm chứng thống kê, Mann–Whitney U xác nhận tách biệt độ trễ hai tầng rất có ý nghĩa ($p < 0.001$); McNemar trên tập thiên tấn công cho $p = 1.0$, và luận văn *không* diễn giải điều này thành ưu thế phát hiện của Tầng 2—xem thảo luận về giới hạn dụng cụ đo ở Mục 5.3.

5.2 Đóng góp Khoa học và Thực tiễn

Khoa học. (1) Một kiến trúc bảo mật nhận thức hai tầng tách lọc tốc-độ-cao tầng-truyền-tải (Tầng 1, thống kê tất định cộng một cổng giảm-tải học) khởi suy luận có trạng thái tầng-nhận-thức (Tầng 2), một khuôn mẫu kết hợp toán học tất định với mô hình ngôn ngữ phi tất định. (2) Một mô hình cách ly mật mã, Đóng gói Dữ liệu Phân định, giải quyết lỗ hổng LLM trước nền-log không tin cậy mà không cần rào chắn phân loại mong manh, tổn tính toán. (3) Một khung đánh giá phi tham số cho tác tử an ninh cục bộ dùng trọng tài LLM chéo họ và metric RAGAS.

Thực tiễn. (1) Một bản mẫu mã nguồn mở, đóng gói container bằng Python điều phối qua Docker Compose, tích hợp llama.cpp và LangGraph. (2) Kiểm chứng phân loại air-gapped cục bộ trên phần cứng phổ thông (i7-14700KF, 32 GB RAM, một RTX 4060 Ti), với một Cổng LightGBM giảm tải 83.8% ca leo thang ở precision 98.82% để giữ suy luận cục bộ khả thi. (3) Một dashboard Streamlit nổi tự động hóa với hàng đợi Con-người-trong-vòng-lặp, bảo vệ log chống giả mạo bằng chuỗi HMAC.

5.3 Các Giới hạn Hiện hữu

Vài giới hạn ràng buộc phạm vi vận hành. *Telemetry:* đánh giá tập trung vào flow mạng và metadata HTTP; các log phi cấu trúc đa dạng (Windows Event, Syslog, CloudTrail) cần thêm cấu hình Drain. *Bão hòa hàng đợi:* một trận quét tốc độ cao hoặc DoS có thể tăng vọt

dị biệt và bảo hòa hàng đợi leo thang dưới compute đơn-GPU. *Đánh đổi tự chủ*: để tránh tự-từ-chối-dịch-vụ, chặn tường lửa do con người quyết, giới hạn tốc độ giảm thiểu tự chủ. *Đầu độc trực tuyến*: checksum vector ngăn giả mạo offline nhưng không ngăn ghi qua kênh được ủy quyền. *Sức mạnh thống kê*: năng lực zero-day kiểm chứng bằng proxy Welford có kiểm soát (biên $\approx 4\sigma$) chứ không phải malware thật; các nghiên cứu APT, đối kháng, và chất lượng suy luận dựa trên mẫu khiêm tốn (ba chiến dịch, Wilson 95% CI [0.44, 1.00] với đối chứng không-báo-giả; bộ 120 payload; ablation 1,250 mẫu thiên-tấn-công và cân bằng 150/150, đều trên một mô hình và một host). Bộ đối kháng do tác giả biên soạn, không thích ứng, và khớp mô hình hạ-cấp mà rào chắn đồng thuận vô hiệu, nên là bằng chứng khái niệm, không phải chứng nhận độ bền; đánh giá trước các benchmark injection công khai và tấn công thích ứng là ưu tiên.

Giới hạn của Dụng cụ Đo

Hai giới hạn thuộc về *phép đo*, không thuộc về artifact, và được nêu ở đây vì chúng ràng buộc mạnh cách đọc các con số.

Thứ nhất, độ phân giải của thước đo nhị phân. Khi quy mọi phán quyết về một nhãn “có phát hiện hay không”, các hành động ESCALATE (Tầng 1 chuyển tiếp) và AWAIT_HITL (tác tử hoãn cho con người) bị gộp cùng ô với BLOCK. Hệ quả là một cấu hình *đẩy quyết định sang tầng sau* được tính điểm ngang một cấu hình *tự quyết đúng*, khiến các cấu hình ablation hội tụ về cùng một giá trị và phép so sánh mất khả năng phân biệt—đây chính là lý do McNemar cho $p = 1.0$ ở trên. Vì vậy luận văn *không* rút ra kết luận về đóng góp phát hiện của từng cấu phần từ thước đo nhị phân; các khẳng định về đóng góp cấu phần chỉ dựa trên những phép đo tách biệt (giảm tải cổng ML, quy kết MITRE, đối chứng âm APT, bộ đối kháng). Một thước đo *chấm theo hành động cuối cùng* đối chiếu hành động kỳ vọng—phân biệt tự quyết đúng, tự quyết sai, và hoãn—là điều kiện cần để định lượng đóng góp từng cấu phần, và được nêu như công việc trước mắt.

Thứ hai, tầng LLM không phải một bộ phân loại. Khi cố tình bỏ qua cổng ML và đẩy thẳng một tập 95% lành tính vào tác tử ($n = 800$), tầng LLM đạt recall 1.00 nhưng specificity 0.00, với accuracy 0.0475 *đúng bằng* mốc đa số—nghĩa là ở chế độ đó nó gần cờ gần như mọi thứ. Con số này không mô tả đường vận hành thật (nơi cổng ML lọc trước), nhưng nó xác lập một ranh giới trung thực: tầng nhận thức đóng vai một *lưới an toàn thiên về độ phủ* kèm khả năng biện minh, chứ không phải một bộ phân biệt lành/độc. Mọi phát biểu trong luận văn về tầng này được giữ trong ranh giới đó.

5.4 Hướng Phát triển Tương lai

Vài hướng tiếp nối. Một phân rã *đa-tác-tử* sẽ tách tác tử nguyên khối thành các tác tử con hợp tác (trích IOC, liên kết playbook, biên dịch luật, báo cáo pháp y). *Học liên kết* sẽ chia sẻ trọng số hoặc tín hiệu uy tín huấn luyện cục bộ giữa các nút mà không trao đổi log thô. *Học tăng cường* sẽ cập nhật tham số sinh luật từ phê duyệt analyst trong hàng đợi HITL. *Tự-củng-cố đối kháng* sẽ triển khai một tác tử đối thủ trong mạng để dò rà soát chặn tự động. *Quy kết dựa-TTP* sẽ đặt một module sinh giả thuyết trên các định danh ATT&CK có cấu trúc, so chuỗi kỹ thuật per-source với hồ sơ MITRE ATT&CK Group bằng độ tương đồng tập có trọng số—trình bày nghiêm ngặt như một giả thuyết xếp hạng để analyst xem, không bao giờ là phán quyết dứt khoát, vì kỹ thuật được chia sẻ giữa các nhóm và quy kết thực cần tình báo vượt xa nghiệp vụ.

Hai năng lực nền tảng cần *trưởng thành hướng-sản-xuất*. Bộ lọc zero-day Tầng 1 hiện là Z-score Welford đơn-biến per-đặc-trưng (biên $\approx 4\sigma$); sản xuất sẽ mở rộng nó tới mô hình đa biến hoặc học nhẹ kiểm chứng trước malware thật. Liên kết APT đa ngày hiện khóa theo IP nguồn (bị đánh bại bởi xoay IP hay fan-out botnet); khóa lại theo kỹ thuật và thực thể ổn định sẽ giữ chiến dịch liên kết được qua hạ tầng đổi thay. Về phương pháp, một tái đánh giá APT trung thực sẽ khóa việc ghi Bộ nhớ Dọa theo phán quyết hai tầng *trực tuyến* (không theo nhãn DAPT2020) và phân vùng lưu lượng theo thời gian bất thật, đếm mỗi ngày bằng nền benign quy-mô-sản-xuất—cho recall đầu-cuối thấp hơn nhưng trung thực và bộc lộ báo-giả-APT, qua đó thúc đẩy khóa-lại theo kỹ thuật/thực thể ở trên.

Lộ trình Mở rộng Ngang

Bản mẫu đơn-host thừa hưởng nút thắt đơn-nút. Một tiến hóa sản xuất theo playbook hệ-phân-tán mà không đổi hợp đồng hai tầng: (i) *phân mảnh bộ lọc Tầng 1 có trạng thái* bằng băm nhất quán trên khóa IP-nguồn, giữ nguyên baseline per-IP và chuỗi APT trong khi năng lực tăng tuyến tính; (ii) thay broker Redis đơn bằng một *commit log phân mảnh, sao chép* (Redis Cluster hoặc Kafka) có khóa phân mảnh khớp khóa shard Tầng 1; (iii) thêm *tiêu thụ idempotent* khóa theo định danh sự kiện tắt định để một tái-giao sau sự cố không thực thi chặn hai lần; (iv) mở rộng Tầng 2 thành một *pool đàn hồi* các worker suy luận phi trạng thái autoscale theo độ sâu hàng đợi, trực tiếp giảm bão hòa trong khi Tầng 1 bảo vệ độc lập; và (v) di trú các kho SQLite sang một *tầng lưu trữ sao chép* (kho key-value quorum cho uy tín/APT, nhất quán mạnh cho audit HMAC và kho luật). Một dashboard phi trạng thái sau load balancer và một rate limiter phía thu nạp hoàn thiện bức tranh. Cho quy mô doanh nghiệp, năm tối ưu cụ thể:

- **Tách microservice:** trích Tầng 2 thành dịch vụ độc lập giao tiếp qua message broker, thoát GIL Python và mở rộng qua nhiều máy chủ.

- **Tầng 1 biên dịch (Go/Rust):** viết lại `RuleEngine` bằng ngôn ngữ hệ thống để loại chi phí JSON và đạt hàng triệu sự kiện/giây.
- **Lưu trữ Kafka:** thay Redis Streams bằng Kafka ghi đĩa để đệm burst volumetric không rủi ro OOM.
- **Batching vLLM/TGI:** thay `llama.cpp` bằng continuous batching dựa PagedAttention để phân xử hàng chục ca leo thang mỗi chu kỳ GPU.
- **Ghi APT theo phán quyết:** khi sản xuất, ghi mọi IP Z-cai hoặc vi phạm luật vào Bộ nhớ Đe dọa kèm mốc thời gian, tự gắn cờ APT nổi lên khi vi phạm trải 2–3 ngày.

Khép lại một nỗ lực khiêm tốn, nhưng mở ra những khát vọng sâu xa trong hành trình bảo vệ không gian số bằng sức mạnh của AI Tác tử.

Tài liệu tham khảo

- [1] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization,” in *Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.
- [2] A. L. Buczak and E. Guven, “A Survey of Data Mining and Machine Learning Methods for Cyber Security Intrusion Detection,” *IEEE Communications Surveys & Tutorials*, vol. 18, no. 2, pp. 1153–1176, 2016.
- [3] G. González-Granadillo, S. González-Zarzosa, and R. Diaz, “Security Information and Event Management (SIEM): Analysis, Trends, and Usage in Critical Infrastructures,” *Sensors*, vol. 21, no. 14, art. 4759, 2021.
- [4] R. Zuech, T. M. Khoshgoftaar, and R. Wald, “Intrusion Detection and Big Heterogeneous Data: A Survey,” *Journal of Big Data*, vol. 2, art. 3, 2015.
- [5] M. Alshamrani *et al.*, “A Survey on Advanced Persistent Threats: Techniques, Solutions, Challenges, and Research Opportunities,” *IEEE Communications Surveys & Tutorials*, vol. 21, no. 2, pp. 1851–1877, 2019.
- [6] S. Tariq, M. Baruwat Chhetri, S. Nepal, and C. Paris, “Alert Fatigue in Security Operations Centres: Research Challenges and Opportunities,” *ACM Computing Surveys*, vol. 57, no. 9, art. 224, 2025.
- [7] Ismail, R. Kurnia, Z. A. Brata, G. A. Nelistiani, S. Heo, H. Kim, and H. Kim, “Toward Robust Security Orchestration and Automated Response in Security Operations Centers with a Hyper-Automation Approach Using Agentic Artificial Intelligence,” *Information*, vol. 16, no. 5, art. 365, 2025.
- [8] B. P. Welford, “Note on a Method for Calculating Corrected Sums of Squares and Products,” *Technometrics*, vol. 4, no. 3, pp. 419–420, 1962.
- [9] P. Lewis *et al.*, “Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks,” *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, pp. 9459–9474, 2020.
- [10] LangChain AI, “LangGraph: Multi-Actor, Stateful LLM Applications,” *GitHub repository*, 2024. [Online]. Available: <https://github.com/langchain-ai/langgraph>
- [11] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.

- [12] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” NIST Special Publication 800-61 Revision 2, 2012.
- [13] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, “Reciprocal Rank Fusion Outperforms Condorcet and Individual Bootstrap Product Algorithms,” in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009.
- [14] R. Pandey and A. Bhujang, “Poisoning the Watchtower: Prompt Injection Attacks Against LLM-Augmented Security Operations Through Adversarial Log Content,” *arXiv preprint arXiv:2605.24421*, 2026.
- [15] F. Blefari, C. Cosentino, F. A. Pironti, A. Furfaro, and F. Marozzo, “CyberRAG: An Agentic RAG cyber attack classification and reporting tool,” *Future Generation Computer Systems*, vol. 176, art. 108186, 2026.
- [16] Z. Liu and A. Anwar, “AutoBnB-RAG: Enhancing Multi-Agent Incident Response with Retrieval-Augmented Generation,” *arXiv preprint arXiv:2508.13118*, 2025.
- [17] J. Zhang *et al.*, “When LLMs Meet Cybersecurity: A Systematic Literature Review,” *Cybersecurity*, vol. 8, 2025.
- [18] A. Abdennebi, N. Kara, L. Lahlou, and H. Ould-Slimane, “LanG – A Governance-Aware Agentic AI Platform for Unified Security Operations,” *arXiv preprint arXiv:2604.05440*, 2026.
- [19] R. Sahay *et al.*, “Policy-Guided Threat Hunting: An LLM Enabled Framework with Splunk SOC Triage,” *arXiv preprint arXiv:2603.23966*, 2026.
- [20] A. Vaswani *et al.*, “Attention is All You Need,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, pp. 5998–6008, 2017.
- [21] A. Gholami *et al.*, “A Survey of Quantization Methods for Efficient Neural Network Inference,” *arXiv preprint arXiv:2103.13630*, 2021.
- [22] J. Johnson, M. Douze, and H. Jégou, “Billion-Scale Similarity Search with GPUs,” *IEEE Transactions on Big Data*, vol. 7, no. 3, pp. 535–547, 2019.
- [23] S. Robertson and H. Zaragoza, “The Probabilistic Relevance Framework: BM25 and Beyond,” *Foundations and Trends in Information Retrieval*, vol. 3, no. 4, pp. 333–380, 2009.
- [24] P. He, J. Zhu, S. He, J. Li, and M. R. Lyu, “Drain: An Online Log Parsing Approach with Fixed Depth Tree,” in *Proceedings of the IEEE International Conference on Web Services (ICWS)*, 2017, pp. 33–40.
- [25] Gemma Team, Google, “Gemma 2: Improving Open Language Models at a Practical Size,” *arXiv preprint arXiv:2408.00118*, 2024.
- [26] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas, “MITRE ATT&CK: Design and Philosophy,” The MITRE Corporation, Technical Report MP180360, 2018.

- [27] N. Reimers and I. Gurevych, “Sentence-BERT: Sentence Embeddings using Siamese BERT-Networks,” in *Proceedings of the Conference on Empirical Methods in Natural Language Processing (EMNLP)*, 2019.
- [28] L. Zheng *et al.*, “Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 36, 2023.
- [29] S. Myneni, A. Chowdhary, A. Sabur, S. Sengupta, G. Agrawal, D. Huang, and M. Kang, “DAPT 2020 – Constructing a Benchmark Dataset for Advanced Persistent Threats,” in *Deployable Machine Learning for Security Defense (MLHat 2020)*, Communications in Computer and Information Science, vol. 1271, Springer, 2020, pp. 138–163.
- [30] S. Es, J. James, L. Espinosa-Anke, and S. Schockaert, “RAGAS: Automated Evaluation of Retrieval Augmented Generation,” *arXiv preprint arXiv:2309.15217*, 2023.
- [31] Q. McNemar, “Note on the Sampling Error of the Difference Between Correlated Proportions or Percentages,” *Psychometrika*, vol. 12, no. 2, pp. 153–157, 1947.
- [32] H. B. Mann and D. R. Whitney, “On a Test of Whether One of Two Random Variables is Stochastically Larger than the Other,” *Annals of Mathematical Statistics*, vol. 18, no. 1, pp. 50–60, 1947.
- [33] H. Krawczyk, M. Bellare, and R. Canetti, “HMAC: Keyed-Hashing for Message Authentication,” Internet Engineering Task Force, RFC 2104, 1997.
- [34] OWASP GenAI Security Project, “OWASP Top 10 for Large Language Model Applications,” Version 2025, The OWASP Foundation, 2025. [Online]. Available: <https://genai.owasp.org/>
- [35] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero Trust Architecture,” NIST Special Publication 800-207, National Institute of Standards and Technology, 2020.